

CYBERSECURITY OPERATIONS FUNDAMENTALS

The Comprehensive Practical Reference for Security Operations Centers

From Monitoring and Detection to Response and Automation

SOC

Prepared and edited by: Abdurhman Taha Gweaa

First Edition - Revised Release, July 2026



The Comprehensive Practical Reference for Security Operations Centers

From Monitoring and Detection to Response and Automation

An academic and practical reference for beginners and practitioners. It explains how security operations center teams monitor threats, qualify alerts, investigate incidents, coordinate response, document evidence, measure performance, and automate repeatable work safely.

Publication and Use Statement

This book is an original educational work based on restructuring, explanation, analysis, and practical synthesis. It is not a literal translation of any training material. The revised release preserves the instructional organization of the original manuscript while correcting language, layout, terminology, cross-references, and technical statements.

All product names and trademarks remain the property of their respective owners. Earlier vendor-interface screenshots have been replaced wherever practical with original conceptual diagrams so that the reader can focus on functions rather than transient product screens.

Examples involving ransomware, threat hunting, malware analysis, vulnerability assessment, and penetration testing are presented strictly from a defensive and authorized perspective. The procedures in this book do not replace an organization's approved policies, legal advice, regulatory requirements, incident response plan, or change-management process.

Review status. This release was reviewed against the official sources listed in the references section, including NIST SP 800-61 Rev. 3, the 2026 Verizon DBIR, M-Trends 2026, FIRST, MITRE ATT&CK, CISA, OASIS, CIS, Security Onion, and TheHive documentation. Technical products and standards continue to change, so official documentation should be checked before converting the material into production controls.

Foreword

A security operations center is no longer merely a room filled with screens. It is an operating model that connects people, processes, data, tools, and governance around one objective: reducing the impact of a threat before it becomes a business crisis.

This book is written for readers who are starting from zero and for engineers, analysts, and managers seeking an integrated view. It begins with definitions and roles, then moves through services, deployment models, staffing, event data, tools, stakeholder relationships, metrics, and automation. Financial-sector and enterprise scenarios provide continuity while the discussion remains defensive throughout.

Current perspective

In April 2025, NIST SP 800-61 Rev. 3 superseded Rev. 2 and reframed incident response as part of cybersecurity risk management under the six functions of the NIST Cybersecurity Framework 2.0. Govern, Identify, and Protect support readiness and improvement; Detect, Respond, and Recover support the active handling of incidents.^{[1][2]}

The threat context has also changed. The 2026 Verizon Data Breach Investigations Report examined more than 31,000 real-world incidents and more than 22,000 confirmed data breaches in 145 countries. It reported that the human element was present in 62% of breaches and that third-party involvement reached 48%.^[14] M-Trends 2026 reported a global median dwell time of 14 days, up from 11 days in the preceding report.^[13]

How to Use This Book

For structured learning

Read the chapters in sequence. Answer the review questions before consulting the model answers. Complete the practical exercise at the end of each chapter.

For building a SOC

Use the service catalogue, role descriptions, RACI examples, playbook structures, metric dictionary, and automation controls as starting points. Tailor them to the organization's risk and authority model.

For daily operations

Return to the “How does the analyst think?” sections, the common mistakes, the investigation questions, and the practical appendices when designing or reviewing workflows.

For review

Use the acronym table, glossary, model answers, subject index, and references to revisit concepts without rereading the entire book.

Learning Map

The chapters progress from “What is a SOC?” to “How do we measure and automate it safely?”

01 - Introduction to the SOC

Mission, terminology, threat actors, dwell time, value, and challenges.

02 - Processes and Services

Service catalogue, monitoring, incident response, recovery, and lessons learned.

03 - Types and Deployment Models

Operational focus, internal ownership, outsourcing, hybrid delivery, and selection criteria.

04 - Building an Effective Team

Tiered roles, extended specialists, handover, staffing, and burnout reduction.

05 - Event Data and Analyst Tools

Evidence types, SIEM, EDR, NDR, network security monitoring, forensics, and correlation.

06 - Relationships with Stakeholders

Internal and external parties, communication plans, RACI, TLP, and crisis coordination.

07 - Understanding SOC Metrics

Speed, accuracy, coverage, process quality, business impact, and metric governance.

08 - Workflow and Automation

Case management, SOAR, APIs, playbooks, human approval, rollback, and automation governance.

Contents

Publication and Use Statement	3
Foreword	4
How to Use This Book	5
Learning Map	6
List of Figures	9
List of Tables	10
Core Acronyms	11
Chapter 1: Introduction to the Security Operations Center	14
Why the SOC Has Become an Organizational Necessity	15
Definition and Core Function	16
Event, Alert, and Incident	16
Threat Actors and Motivations	18
Ransomware and the Qilin Scenario	19
Organizational Value and Challenges	21
Chapter 2: Security Operations Center Processes and Services	24
From Monitoring Team to Service Capability	25
Incident Response Lifecycle	26
Collaboration and Detection Feedback	29
Chapter 3: SOC Types and Deployment Models	33
SOC Types by Operational Focus	34
Deployment Models	36
Selecting a Model	37
Chapter 4: Building an Effective SOC Team	41
Tiered Roles and Extended Specialists	42
Role Interaction During an Incident	46

Burnout, Staffing, and Handover	47
Chapter 5: Security Event Data and Analyst Tools	49
Network and Security Data Types	51
SIEM, EDR, NDR, NSM, and Analysis Tools	54
Correlation, Data Quality, and Evidence	56
Chapter 6: Relationships with Stakeholders	60
Internal and External Stakeholders	61
FIRST, NIST, and Communication Planning	63
RACI, TLP, Channels, and Crisis Communication	64
Chapter 7: Understanding SOC Metrics	69
Time Definitions and Detection Outcomes	71
A Balanced Metric Family	74
Dashboards, Business Value, and Metric Governance	76
Chapter 8: Workflow Management and Automation	80
Workflow Management and Workflow Types	81
Integration, APIs, STIX, and TAXII	84
Human-in-the-Loop and Automation Governance	85
Practical Appendices	90
Model Answers and Exercises	93
Concise Glossary	105
Subject Index	107
References and Sources	108

List of Figures

Figure 1-1. NIST CSF 2.0 functions and the SOC	15
Figure 1-2. From events to incidents	16
Figure 1-3. Simplified attack progression	20
Figure 1-4. Defensive ransomware flow for a file share	21
Figure 2-1. Operational incident response lifecycle	27
Figure 3-1. SOC deployment models	36
Figure 4-1. Core SOC roles and responsibility layers	42
Figure 4-2. Security analyst functional model	45
Figure 5-1. Security event data types	51
Figure 5-2. Question-led investigation method	53
Figure 6-1. Incident response stakeholder map	61
Figure 7-1. From telemetry to coordinated response	70
Figure 7-2. Incident lifecycle time points	71
Figure 7-3. Detection outcome matrix	73
Figure 8-1. Workflow patterns	82
Figure 8-2. Governed automation workflow	86

List of Tables

Table 1-1. Event, alert, and incident	17
Table 1-2. Threat actors, motives, targets, and signals	18
Table 1-3. Common SOC challenges and practical controls	22
Table 2-1. Initial SOC service catalogue	26
Table 2-2. Pre-authorized containment and approval boundaries	28
Table 3-1. SOC types by operational focus	35
Table 3-2. Deployment model comparison	37
Table 4-1. IOA and IOC comparison	45
Table 5-1. Security event data types	52
Table 5-2. Attack activities and useful data	53
Table 5-3. Investigation questions, sources, and tools	57
Table 6-1. Example ransomware RACI	65
Table 7-1. Detection-control outcomes	73
Table 7-2. Balanced executive SOC dashboard	75
Table 8-1. Workflow types	82

Core Acronyms

Core acronyms used in the book

Acronym	English term	Practical meaning
SOC	Security Operations Center	An organizational capability that monitors, investigates, coordinates response, and improves detection.
SIEM	Security Information and Event Management	Centralized collection, normalization, search, correlation, alerting, and reporting for security data.
SOAR	Security Orchestration, Automation, and Response	Coordination and automation of security workflows across tools and teams.
WMS	Workflow Management System	A generic term used in this book for a platform that manages tasks, states, approvals, and audit trails.
EDR	Endpoint Detection and Response	Endpoint telemetry, detection, investigation, containment, and response.
XDR	Extended Detection and Response	Integrated detection and response across multiple security domains.
NDR	Network Detection and Response	Network behavior analytics, detection, investigation, and response.
IDS/IPS	Intrusion Detection / Prevention System	Detection of suspicious traffic; an IPS may also block or drop traffic.
IOC	Indicator of Compromise	An artifact associated with compromise, such as a hash, domain, or registry value.
IOA	Indicator of Attack	Behavior or intent that suggests an attack is in progress.
TTPs	Tactics, Techniques, and Procedures	Patterns describing how adversaries pursue objectives.
CSIRT	Computer Security Incident Response Team	A team that provides incident-management services to a defined constituency.
PSIRT	Product Security Incident Response Team	A team focused on vulnerabilities and incidents affecting a vendor's products.
TTD	Time to Detect	Detection time for one incident, using a defined start and end point.
MTTD	Mean Time to Detect	Arithmetic mean of detection times across a defined and comparable set of incidents.
MTTA	Mean Time to Acknowledge	Average time from alert creation to analyst acknowledgment or queue acceptance.
MTTR	Mean Time to Respond / Remediate / Recover	An ambiguous acronym whose exact local definition must be documented.
SLA	Service Level Agreement	Defined service target, responsibility, and time commitment.
RACI	Responsible, Accountable, Consulted, Informed	A responsibility-assignment model for tasks and decisions.
TLP	Traffic Light Protocol	FIRST labels that define information-sharing boundaries.
PCAP	Packet Capture	Captured network packets, usually stored in a pcap-format file.
IPFIX	IP Flow Information Export	A standard for exporting network-flow information.
UEBA	User and Entity Behavior Analytics	Analytics that identify unusual behavior by users and entities.
DLP	Data Loss Prevention	Controls intended to prevent or detect unauthorized disclosure or exfiltration.
MFA	Multi-Factor Authentication	Authentication using more than one factor category.
C2	Command and Control	Adversary communication used to control compromised systems.

Acronym	English term	Practical meaning
CMDB	Configuration Management Database	A repository of assets, services, relationships, and configuration information.
API	Application Programming Interface	A defined interface that enables systems to exchange data or commands.
STIX	Structured Threat Information Expression	An OASIS language for representing cyber threat and observable information.
TAXII	Trusted Automated Exchange of Intelligence Information	An OASIS application-layer protocol for exchanging cyber threat information.

01

THE FOUNDATION OF MODERN DEFENSIVE OPERATIONS

Introduction to the Security Operations Center

Mission, terminology, threat actors, dwell time, value, and operational challenges

Learning outcomes

- Define the SOC and explain its business value.
- Distinguish event, alert, and incident.
- Understand threat actors, attack progression, and dwell time.
- Apply first-response reasoning to a ransomware scenario.
- Identify people, process, technology, and governance challenges.

Why the SOC Has Become an Organizational Necessity

Cyberattacks are part of the daily risk landscape for financial institutions, government entities, critical-infrastructure operators, and ordinary enterprises. A serious intrusion rarely consists of one malicious file on one device. It may begin with phishing, an exposed service, a compromised supplier, or a stolen account; continue through privilege escalation and lateral movement; and end with data theft, fraud, encryption, or service disruption.

An organization therefore needs a persistent operational capability that monitors the environment, connects weak signals, determines whether a genuine security condition exists, coordinates action, and records evidence and decisions. The 2026 Verizon DBIR examined more than 31,000 incidents and more than 22,000 confirmed breaches. It found that vulnerability exploitation had become the most common initial-access vector in its dataset, while the human element remained present in 62% of breaches and third-party involvement reached 48%.^[14]

Central idea. A SOC is not a room filled with screens and it is not another name for a SIEM. It is an integrated operating capability that combines people, process, technology, data, and governance to reduce security risk and business harm.

NIST CSF 2.0 functions and the SOC



Govern, Identify, and Protect support readiness; Detect, Respond, and Recover drive incident operations.

Figure 1-1. The six NIST CSF 2.0 functions place security operations inside enterprise cybersecurity risk management.

Definition and Core Function

A security operations center can be defined as a centralized or coordinated capability for monitoring security-relevant activity, qualifying alerts, investigating incidents, and coordinating response. It may be a physical room, a distributed internal team, a remotely delivered service, or a hybrid arrangement. The organizational form varies, but the core functions are broadly consistent:

- Collect relevant telemetry from endpoints, networks, identity systems, applications, databases, cloud platforms, and security controls.
- Monitor events and alerts during the approved operating hours, including 24/7 where risk requires it.
- Perform triage, enrichment, severity assignment, and escalation.
- Correlate evidence across sources and determine scope, timeline, and impact.
- Coordinate containment, eradication, and recovery with operational teams.
- Document evidence, hypotheses, decisions, approvals, communications, and results.
- Improve detection rules, playbooks, controls, training, and risk treatment after incidents.
- Provide operational, executive, compliance, and audit reporting.

The objective is not to maximize the number of alerts or tickets closed. It is to reduce the likelihood that malicious activity causes a loss of confidentiality, integrity, or availability, and to reduce downtime, financial loss, regulatory exposure, and damage to trust.

Event, Alert, and Incident

A common beginner error is to treat every event as an incident or every alert as proof of compromise. The three terms represent different levels of interpretation.

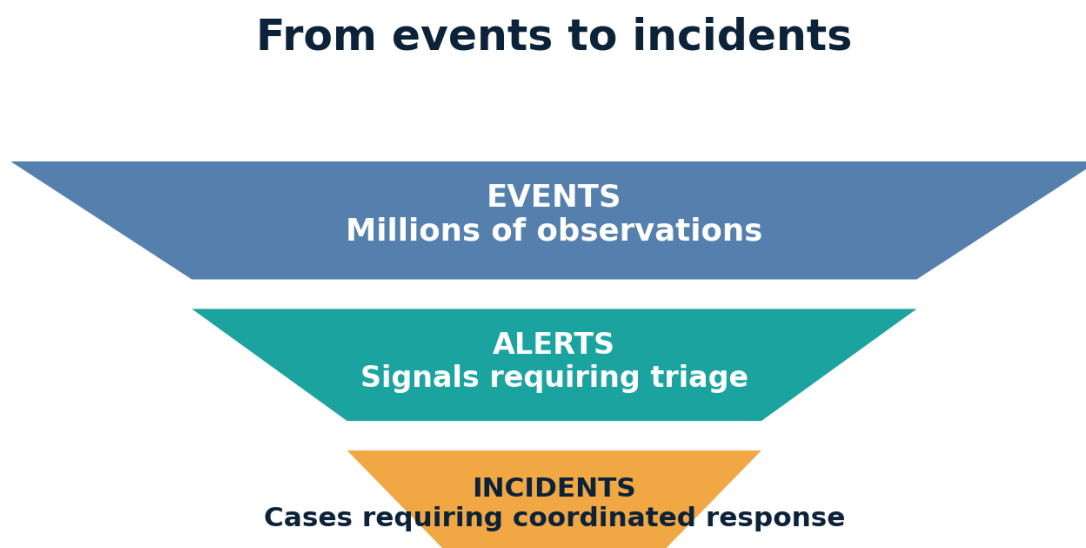


Figure 1-2. A large volume of events is narrowed into alerts requiring triage and a smaller number of incidents requiring coordinated response.

Table 1-1. Event, alert, and incident

Element	Question answered	Example	Normal action
Event	What happened?	A successful sign-in or a DNS query	Store, monitor, and correlate with context.
Alert	Does a pattern warrant review?	Repeated failures followed by success from an unusual source	Triage, enrich, validate, and assign priority.
Incident	Is there an actual or imminent security impact?	A compromised account accessed a customer database	Activate incident response and containment.

Event

An event is any observable occurrence involving a system or network. Examples include a successful sign-in, a failed authentication, process execution, a file modification, a firewall connection, a DNS query, or a database query. An event may be entirely normal and may have no security meaning by itself.

Alert

An alert is a notification generated by a rule, analytic, or product when activity warrants review. It is an automated hypothesis, not a final judgment. An alert may be a true positive, a false positive, or technically correct but benign in business context, such as an approved backup job that modifies thousands of files.

Incident

An incident is an occurrence that actually or imminently jeopardizes policies, operations, or the confidentiality, integrity, or availability of information and therefore requires organized management and response. Examples include confirmed use of a stolen account, ransomware affecting a file share, data exfiltration, or unauthorized creation of a privileged account.

The SOC as a Frontline Operational Defense

The SOC is often described as a “first line of defense,” but that phrase can be confused with governance models such as the Three Lines Model. A clearer description is *frontline operational defense*: the SOC receives signs of danger and turns them into coordinated action. It is not the organization's only security control. Protection also depends on architecture, secure configuration, identity controls, patching, segmentation, awareness, backups, and business continuity.

Before an attack

- Identify critical assets and owners.
- Establish baselines of normal behavior.
- Onboard and validate important log sources.
- Develop use cases, playbooks, and runbooks.
- Use threat intelligence and threat modeling.
- Conduct tabletop exercises and recovery tests.

During an attack

- Detect and qualify malicious activity.
- Determine scope and business impact.
- Stop command-and-control, exfiltration, or destructive activity.
- Coordinate containment and communications.
- Preserve evidence when required.

After an attack

- Remove malware, persistence, unauthorized access, and exploited weaknesses.
- Restore services from trusted sources.
- Perform root-cause analysis and lessons learned.
- Update detections, controls, playbooks, and the risk register.

Threat Actors and Motivations

A threat actor is a person, group, or entity that conducts or supports harmful activity. Classification should not be based solely on a tool or malware family; motive, capability, resources, access, and objectives matter.

Table 1-2. Threat actors, motives, targets, and signals

Category	Common motive	Potential targets	Signals relevant to the SOC
Organized crime	Financial gain and extortion	Payment systems, customer data, backups	Credential theft, exfiltration, fraud, and ransomware behavior
State-affiliated actor	Espionage, influence, or disruption	Critical infrastructure, communications, research	Long dwell time, stealth, custom tooling, and strategic targeting
Insider	Revenge, personal gain, negligence, or compromised identity	Employee and customer data, internal systems	Bulk export, unusual access, policy violations, or anomalous privilege use
Hacktivist	Political or social motive	Public services, websites, and reputation	DDoS, defacement, leaks, and publicity-driven activity
Opportunistic attacker	Exploitation of visible weaknesses	Any exposed service or account	Scanning, default credentials, exploit attempts, and commodity malware

What attackers seek

- Customer accounts, transactions, and payment data.
- Employee, payroll, personally identifiable information, and intellectual property.
- Credentials, tokens, cryptographic keys, and privileged access.
- Sensitive email, documents, source code, and business plans.
- The ability to control, disrupt, or use the organization's infrastructure for further attacks.

In a financial institution, an asset's value is not limited to the cost of the server. Compromise of Active Directory, payment systems, backup management, virtualization infrastructure, or a cloud control plane can amplify impact across the entire environment.

Common Entry Methods: Phishing and Social Engineering

Phishing

A message, website, QR code, or call impersonates a trusted party and attempts to persuade a user to open an attachment, follow a link, enter credentials, approve an MFA request, install software, or authorize a fraudulent transaction. The analyst should not inspect only the link or attachment. The investigation asks who received it, who interacted with it, whether credentials were entered, whether a process ran, whether the message spread internally, and how the account or device was used afterward.

Social engineering

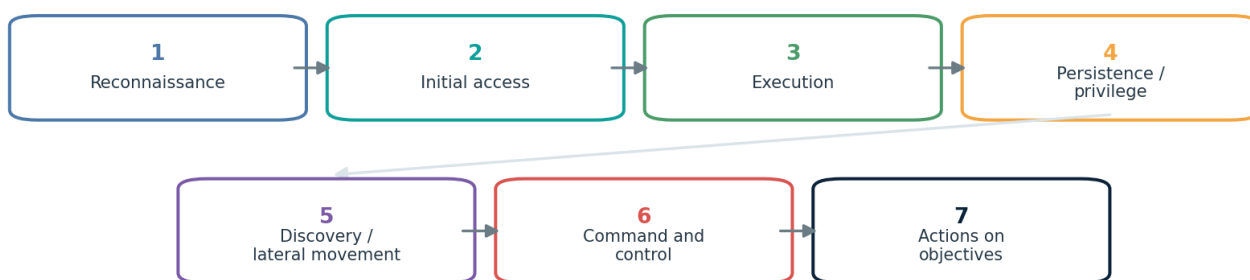
Social engineering manipulates people and trust rather than attacking technology alone. An adversary may use public information, organizational structure, a manager's writing style, or a supplier relationship to make a request appear legitimate. Voice and mobile-centric pretexting require different awareness and verification controls from ordinary email phishing. The 2026 DBIR reported higher success in mobile-centric simulation vectors than in email simulations.^[14]

Ransomware: Encryption Is Not the Whole Story

Modern ransomware operations may combine initial access, credential theft, privilege escalation, discovery, lateral movement, defense evasion, data staging and exfiltration, disabling security and recovery controls, encryption for impact, and extortion. Backups are essential, but they do not prevent data theft, fraud, public disclosure, or attacks against backup credentials and management systems.

CISA's updated StopRansomware guidance treats preparation, response, and recovery as one plan that includes MFA, patching, segmentation, endpoint protection, evidence preservation, tested backups, and organized communications.^[12]

Simplified attack progression



Real intrusions may skip, repeat, or parallelize stages; use ATT&CK tactics and techniques for deeper analysis.

Figure 1-3. A simplified attack progression. Real incidents may skip, repeat, or parallelize stages; MITRE ATT&CK provides a more detailed behavior-based language.

Zero-day: what it means and what it does not mean

A zero-day vulnerability is a software or hardware weakness for which defenders do not yet have an effective vendor fix or adequate public knowledge at the time it becomes relevant. A *zero-day exploit* uses such a weakness. Unknown malware is not automatically a zero-day; it may be a new variant, an obfuscated file, or a signature gap. When signatures are unavailable, analysts rely on behavior, process trees, command lines, memory artifacts, network anomalies, and known adversary techniques.

Dwell time and time to detect

Dwell time is the period from an adversary's initial compromise until detection, using the exact definition adopted by the reporting organization. Longer dwell time creates more opportunity for discovery, persistence, privilege escalation, theft, and concealment. Historical figures of 100 to 200 days illustrate the scale of the problem but should not be treated as modern targets. M-Trends 2026 reported a global median dwell time of 14 days for the cases it investigated, with much longer medians in some espionage and North Korean IT-worker-related cases.^[13]

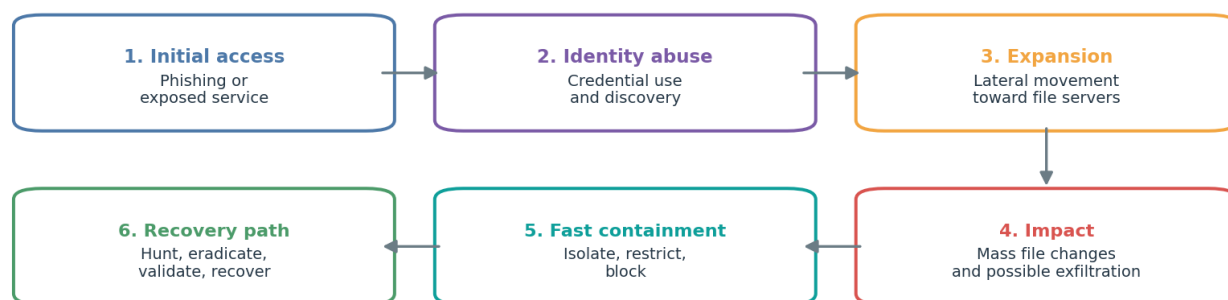
Measurement rule. Do not claim “we detected it quickly” without defining the start point. Is it initial compromise, the first malicious event, the first log available to the SOC, or alert creation? A metric is not comparable until its boundaries are standardized.

Cumulative case study: Qilin-like ransomware on a domain-joined Windows file share

The chapters use a progressive defensive scenario: a domain-joined user device is compromised; the account reaches a Windows file share; mass file changes, a ransom note, and suspicious outbound communication appear; the activity attempts to reach additional servers; and the SOC must contain the threat while investigating scope and root cause.

MITRE describes Qilin as a ransomware family operated as ransomware-as-a-service, with variants capable of targeting Windows, Linux, and VMware ESXi environments.^[7] This does not mean every mass-encryption case is Qilin. Attribution requires evidence from malware samples, infrastructure, behavior, and forensics.

Defensive flow for ransomware on a domain-joined file share



Containment and investigation proceed in parallel; attribution is not required before stopping active harm.

Figure 1-4. A defensive flow for a ransomware incident affecting a domain-joined file share and supporting infrastructure.

```

Host: FIN-PC07
User: DOMAIN\finance.user
Target: \FILE-SRV01\Finance
Files modified: 8,400 in 9 minutes
External connection: suspicious destination
  
```

The priority is not to wait for the ransomware family name. Under a pre-approved playbook, parallel actions may include isolating the source endpoint, restricting the account and revoking sessions, terminating SMB sessions, protecting backups and management interfaces, opening a critical incident, appointing an incident manager, and hunting for the same account, indicators, or behavior elsewhere.

Why not wait for traditional escalation? Escalation must not mean that work stops. Tier 1 can activate a defined fast-containment path for clear, high-impact conditions while Tier 2 and Tier 3 continue determining scope and root cause. The path requires explicit authority, approval limits, verification, and rollback.

Organizational Value and Challenges

Protecting business continuity

Every minute of downtime affecting a payment platform, hospital system, or customer service can become an operational loss and an erosion of trust. The SOC does not replace business continuity management, but it reduces the probability that an alert develops into a widespread outage.

Reducing breach impact

Early detection and containment can limit the number of affected records, devices, accounts, and services. It also gives legal, privacy, management, and regulators a more accurate basis for decision-making.

Improving security posture

Every incident should improve controls, logging, detection rules, asset inventory, access control, playbooks, training, and the risk register. Closing a ticket without feeding lessons back into the environment wastes part of the value of the investigation.

Supporting governance and compliance

The SOC provides evidence that the organization monitors, responds, documents, and learns. Compliance is not the same as security, but reliable operational evidence supports audit and accountability.

Table 1-3. Common SOC challenges and practical controls

Domain	Problem	Likely impact	Practical control
Technology	Unstable or missing telemetry	Blind spots and misleading metrics	Log-source onboarding, parser testing, sensor-health monitoring, and retention design
People	Alert fatigue, skill gaps, and concentration of knowledge	True positives may be missed; response becomes fragile	Tuning, automation, staffing, mentoring, documentation, and fair shifts
Process	Unclear escalation or isolation authority	Delay, arbitrary action, or service disruption	Playbooks, RACI, approval matrix, exercises, and reversible actions
Governance	Activity reports not linked to risk or business outcomes	Misguided investment and weak accountability	Metric dictionary, KPIs tied to risk, owners, targets, and review dates

How does a SOC analyst think?

1. What happened, and when did it begin?
2. Which user, device, service, and data are affected?
3. Is the behavior normal in this business context?
4. What evidence is available, and what is missing?
5. Is the threat still active?
6. Is immediate containment required?
7. What is the possible scope beyond the first asset?
8. Is the case a false positive, benign activity, a policy violation, or an incident?
9. Who must be involved, informed, or asked to approve an action?
10. What must be documented and improved after closure?

Common mistakes

- Treating every alert as confirmed compromise.
- Closing an alert because it “looks administrative” without evidence.
- Focusing on the malware family name while damage continues.
- Isolating one device without hunting for identity abuse or lateral movement.
- Restoring from backup before eradication and validation.

- Relying on a single reputation result or indicator.
- Ignoring business criticality and the impact of containment.
- Believing that purchasing a SIEM means the organization has a SOC.
- Failing to record decisions, timestamps, queries, and evidence.

Chapter summary

A SOC is a coordinated operating capability that connects monitoring, analysis, response, documentation, and continuous improvement. Its work begins by distinguishing events, alerts, and incidents; understanding actors, entry methods, attack behavior, and dwell time; and turning each incident into stronger controls. Its value appears when it protects the business and reduces harm, while its success depends as much on people, process, and governance as it does on tools.

Chapter review questions

1. What is the most accurate description of the SOC's core function?
2. Explain the difference between an event, an alert, and an incident with one example.
3. What is dwell time, and why does it matter to management?
4. Which persons or groups can be threat actors?
5. EDR observes 4,000 file changes on a file share in six minutes. What are the first two decisions?
6. Why are backups alone insufficient against modern ransomware?
7. Why is unknown malware not automatically a zero-day?
8. Name two people challenges and two technology challenges inside a SOC.
9. Give an example of a false positive that may resemble ransomware.
10. How does a SOC demonstrate business value?

Practical exercise

Write a six-point timeline for ransomware affecting a Windows file share. Identify the assumed start of dwell time, the first pre-authorized containment action, the evidence that must be preserved, and the business owner who must be involved.

Security Operations Center Processes and Services

Turning monitoring into a service-based operating capability.

Learning outcomes

- Explain SOC services before, during, and after an incident.
- Build an initial SOC service catalogue.
- Apply an iterative incident response life-cycle.
- Distinguish containment, eradication, and recovery.
- Coordinate work with IT, NOC, identity, legal, HR, and business owners.
- Return incident findings to the detection feedback loop.

From a Monitoring Team to a Service-Based Capability

A SOC does not provide one service and should not be defined as a team that watches a SIEM dashboard, converts alerts into tickets, and stops there. It supports an incident throughout its lifecycle: before the incident through preparation and visibility; during the incident through triage, investigation, coordination, and containment; and after the incident through recovery support, reporting, lessons learned, and detection improvement.

A service catalogue makes this work explicit. It states what the SOC provides, who receives the service, the operating hours, the expected output, the partners required for delivery, and the boundaries of authority. The value of this definition becomes obvious during the first major incident. Without it, isolation, account disablement, backup restoration, evidence preservation, and communication become a chain of waiting while the adversary continues operating.

FIRST's CSIRT Services Framework organizes services into a structured hierarchy and emphasizes that a team selects a portfolio that fits its mandate, constituency, resources, and maturity; no team is expected to provide every possible service.^[3]

Services before an incident

- Asset, identity, cloud, application, and log-source onboarding.
- Security monitoring design and detection-use-case development.
- Sensor-health, parser, retention, and time-synchronization monitoring.
- Threat-intelligence requirements, enrichment, and watchlists.
- Vulnerability and exposure context for prioritization.
- Playbook, runbook, contact-list, and escalation-matrix development.
- Training, tabletop exercises, simulations, and recovery tests.

Services during an incident

- Alert triage, qualification, severity assignment, and case creation.
- Incident analysis, scope determination, and timeline reconstruction.
- Malware, email, endpoint, identity, network, cloud, and artifact analysis.
- Containment recommendation, approval, execution coordination, and verification.
- Threat hunting, evidence collection, and stakeholder communication.
- Operational, technical, executive, and regulatory reporting.

Services after an incident

- Eradication and recovery support.
- Forensics, root-cause analysis, and final reporting.
- Lessons learned and corrective-action tracking.
- Detection feedback, rule tuning, and playbook improvement.
- Knowledge transfer, awareness, risk-register updates, and control validation.

Table 2-1. Initial service catalogue for a security operations center

Service area	Service	Measurable outputs	Delivery partners
Monitoring	Continuous or scope-defined monitoring	Queue health, sensor status, latency, and coverage	SIEM/platform team, NOC, system owners
Event analysis	Triage, correlation, and qualification	Disposition, severity, evidence, and next action	Tier 1, Tier 2, asset and identity owners
Incident management	Manage scope, tasks, timeline, decisions, and response	Incident record, containment plan, status reports, and final report	CSIRT, IT, NOC, identity, legal, business owners
Threat intelligence	Enrichment, intelligence requirements, and hunting inputs	Context, IOCs, TTPs, watchlists, and confidence	Threat intelligence team, providers, national or sector CSIRT
Forensics support	Preserve and analyze evidence	Images, hashes, chain-of-custody records, findings	Forensics, legal, privacy, system owners
Reporting	Operational, executive, compliance, and regulatory reporting	Dashboards, status updates, evidence packages, final reports	CISO, management, GRC, legal
Improvement	Lessons learned, tuning, validation, and training	Updated rules, playbooks, controls, owners, and due dates	Detection engineering, IT, risk, awareness

Daily operations do not stop during a crisis

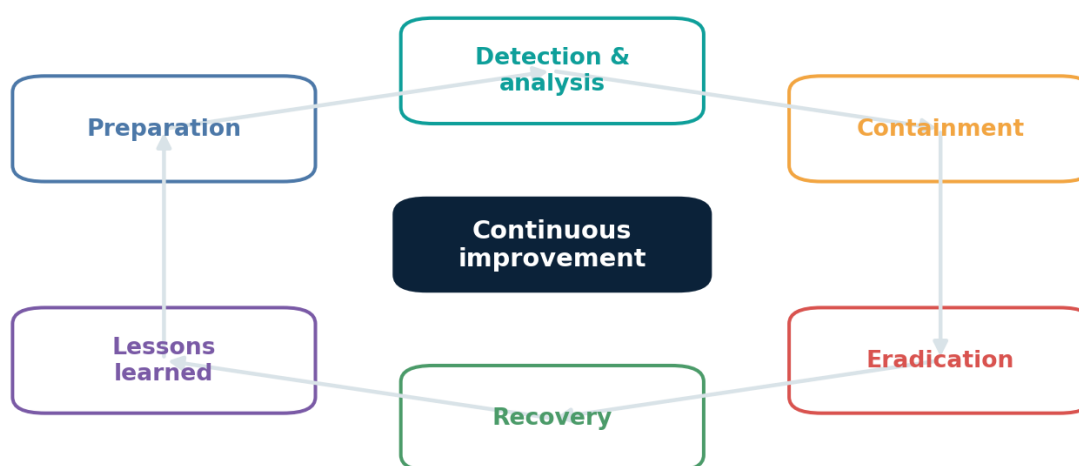
During ransomware or a major data breach, assigning every analyst to the same incident can create a new blind spot. A parallel campaign may be active, another attacker may exploit the distraction, or the incident may be one part of a wider intrusion. The operating model should preserve business-as-usual monitoring while a dedicated incident cell handles the major case.

- A defined portion of the team retains responsibility for the alert queue and critical sensor health.
- An incident manager allocates a dedicated response team and activates on-call staff according to severity.
- Shift handover records open incidents, watch items, pending approvals, and risks.
- Rules define when routine work can be deferred and when emergency staffing is required.

An Operational Incident Response Lifecycle

The six-phase lifecycle - preparation; detection and analysis; containment; eradication; recovery; and lessons learned - remains useful for training and operations. It should not be treated as a rigid one-way sequence. New evidence during recovery may return the team to analysis or containment. NIST SP 800-61 Rev. 3 places these operational activities inside the broader CSF 2.0 risk-management cycle rather than treating incident response as an isolated function.^{[1][2]}

Operational incident response lifecycle



The phases are iterative. New evidence can return the team to analysis or containment.

Figure 2-1. An operational incident response lifecycle. The phases are iterative, and continuous improvement connects lessons learned to preparation.

1. Preparation

Preparation means building the ability to make safe decisions before a crisis. Essential elements include an approved policy and plan; severity and priority definitions; asset inventory and criticality; contact lists and on-call rosters; playbooks and standard operating procedures; authority to isolate, block, disable, or restrict; tested backups; forensic tools; secure alternate communications; and exercised coordination with internal and external stakeholders.

Why preparation matters more than a product. A tool may correctly report “mass encryption detected,” but the organization may still be unable to act if it does not know who owns the file server, who can terminate SMB sessions, who approves stopping the share, which backup is trusted, or how to communicate if the identity environment is compromised.

2. Detection and analysis

This phase converts a signal into an evidence-based understanding. The analyst determines whether the activity is a true positive, false positive, benign positive, policy violation, technical failure, or incident. Even a non-security failure can require incident-level urgency when a critical service is unavailable.

Core triage questions

- Is the alert genuine, and what evidence supports the disposition?
- Which asset, account, application, data, and business service are affected?
- Is the activity ongoing, and what is the earliest known time?
- What telemetry is available, missing, delayed, or unreliable?
- What are the likely severity, confidence, and business impact?
- Are there related alerts, cases, identities, devices, or destinations?

Incident reports may originate from SIEM, EDR, NDR, email security, users, helpdesk, threat hunting, a vendor, a customer, a researcher, a national CSIRT, or an external organization that observes abuse from the environment. The team needs one intake process that acknowledges receipt, protects sensitive information, links related reports, and avoids duplicate cases.

3. Containment

Containment stops continuing damage or spread. It does not necessarily remove the attacker or the root cause. Actions may include isolating an endpoint, revoking sessions and tokens, disabling or restricting an account, terminating SMB or RDP sessions, blocking a destination, segmenting a zone, disabling a vulnerable service, protecting backups, or placing a share into a restricted mode.

Table 2-2. Simplified pre-authorized containment and approval boundaries

Action	Suitable for pre-authorization or automation	Condition requiring higher approval
Isolate a user endpoint	High-confidence malicious behavior, active encryption, or C2; action is reversible	Executive, medical, industrial, safety, or operationally sensitive endpoint
Restrict an ordinary account	Strong evidence of account compromise; defined rollback and notification	Privileged, break-glass, service, shared, or high-impact account
Block an indicator	High-confidence indicator with no legitimate service relationship	Shared cloud/CDN, critical supplier, official domain, or uncertain confidence
Terminate a session	Active malicious session and low operational impact	Session supports a critical transaction or emergency process
Stop or isolate a server	Rarely pre-authorized; only under narrowly defined emergency conditions	Normally requires system owner and incident manager; executive approval may be required

Balanced containment considers expected damage, evidence preservation, service continuity, confidence, reversibility, rollback, and the risk that disconnection changes adversary behavior. A containment action should be verified: a successful API response is not enough if the host remains connected or the account retains active tokens.

4. Eradication

Eradication removes malicious presence and the cause that enabled it. Tasks can include deleting malware and persistence; removing unauthorized tasks, services, registry entries, accounts, and privileges; patching the exploited weakness; rotating credentials, secrets, certificates, and API keys; rebuilding systems whose integrity cannot be trusted; and confirming that the full scope has been examined.

Containment is not eradication. Blocking one C2 address may stop communication temporarily, but it does not remove malware or persistence. The implant may switch destinations or return after the block expires.

5. Recovery

Recovery returns systems, data, and services to a safe and acceptable state. It includes restoration from trusted backups or clean images; configuration and permission review; increased logging and monitoring; staged reconnection; business and system-owner validation; and a defined recovery gate confirming that the minimum eradication and security checks are complete. NIST SP 800-184 emphasizes planned, tested, mission-aligned cyber recovery rather than ad-hoc restoration.^[19]

Restoring a file server while a compromised account, malicious token, exposed management plane, or persistence mechanism remains can restart encryption within minutes. Recovery is therefore a controlled decision, not merely a backup operation.

6. Lessons learned

The lessons-learned phase converts an incident into improved capability. The review should establish the timeline, initial access, root cause, scope, detection successes and gaps, approval delays, logging and retention limitations, playbook performance, business impact, and corrective actions. Each action needs an owner, due date, priority, evidence of completion, and a validation method.

Typical outputs

- Updated detection rules, hunts, blocklists, and data-source requirements.
- Updated playbooks, runbooks, escalation paths, contact lists, and approval boundaries.
- Patching, segmentation, access-control, backup, and configuration improvements.
- Targeted awareness and technical training.
- Risk-register, business-continuity, and supplier-management updates.
- New or corrected metrics and a clearer metric definition.

Collaboration and Detection Feedback

NOC and IT operations

Execute network and infrastructure changes, stop or restore services, retrieve logs, and validate operational impact. The SOC supplies analysis, priority, and verification criteria.

Identity and endpoint teams

Restrict accounts, revoke tokens, review groups and privileges, rebuild devices, deploy endpoint controls, and validate identity recovery.

Email team

Trace messages, identify recipients and clicks, search and purge, block senders or domains, and preserve message evidence.

Database and application teams

Interpret audit logs and transactions, identify affected data, apply patches or code fixes, and test business functionality.

Legal, privacy, and compliance

Assess breach obligations, monitoring authority, evidence handling, regulatory reporting, legal privilege, and external sharing.

HR and public affairs

Support employee cases, awareness, workforce communication, and authorized public or media messaging.

Malware, artifact, and forensic services

The SOC may require static analysis, sandbox execution, reverse engineering, memory analysis, disk forensics, cloud forensics, or timeline reconstruction. These services may be internal or external. Artifacts should be isolated, hashed, documented, and handled through an approved evidence process. They must never be executed on a normal workstation. NIST SP 800-86 remains a foundational reference for integrating forensic techniques into incident response.^[18]

Detection feedback loop

Incident findings

- > confirmed indicators, behaviors, root cause, and gaps
- > SIEM / EDR / NDR / firewall / identity / email detections
- > threat-hunting queries and coverage tests
- > playbook, training, and control updates
- > better detection and faster, safer response

If the team closes an incident without updating detections, controls, or process knowledge, the organization has paid the cost of the incident without receiving the full value of what it learned.

Integrated scenario: phishing leading to malware

A user reports “Updated Payment Schedule,” a message containing a suspicious attachment. Tier 1 collects the message, headers, message ID, sender, URLs, hashes, recipients, click telemetry, and endpoint context. Tier 2 analyzes the process tree, command line, network connections, and the sample in an isolated environment; determines C2 and scope; recommends endpoint isolation and session revocation; and coordinates search and purge. Tier 3 hunts for the same behaviors, reviews credential access and lateral movement, maps techniques to ATT&CK, and creates improved detections. Email, identity, NOC, HR, and legal join according to scope and impact.

Integrated scenario: Qilin-like ransomware on a file share

1. Tier 1 opens a critical incident and does not wait for attribution.
2. The endpoint is isolated and SMB access is terminated under the pre-approved path.
3. The identity team restricts the account and revokes sessions.
4. Tier 2 determines scope, identifies other affected devices and shares, and searches for C2 and exfiltration.
5. Tier 3 examines initial access, privilege escalation, persistence, lateral movement, and malware artifacts.

6. The backup team protects copies, management interfaces, and administrative credentials.
7. The incident manager coordinates business impact, communication, and recovery.
8. Restoration occurs in stages after eradication, validation, and approval.

CISA's StopRansomware guidance similarly emphasizes isolation, preservation of evidence, protection of backups, and searching for spread before restoration.^[12]

How does an analyst think within the process?

- What phase or state is the case in, and can it move backward?
- Is the threat active, and what action has the greatest risk-reduction value now?
- What is the minimum evidence needed for the next decision?
- Is the proposed action reversible, and who owns execution and approval?
- Will the action destroy evidence or create unacceptable business impact?
- Which part of the possible scope has not been tested?
- Will recovery reintroduce the same weakness?
- What knowledge must return to detection, risk, and training?

Common mistakes

- Assigning every analyst to one incident and abandoning routine monitoring.
- Confusing containment with eradication.
- Waiting for complete analysis before stopping active high-impact damage.
- Isolating a device but leaving the compromised identity and tokens usable.
- Restoring from backup before validating environmental integrity.
- Closing a case without root cause, corrective actions, owners, or due dates.
- Treating a playbook as a static document that does not require testing.

Chapter summary

SOC services span the periods before, during, and after an incident. Effective operations combine preparation, detection and analysis, containment, eradication, recovery, and lessons learned with clear responsibilities across security, IT, identity, legal, HR, business owners, and external specialists. Success is not rigid phase compliance; it is making evidence-based decisions at the right time, maintaining visibility over the wider environment, and turning each incident into stronger capability.

Chapter review questions

1. Why must part of the SOC continue routine monitoring during a major incident?
2. List the six operational incident response phases.
3. What is the difference between containment and eradication?
4. Who normally executes infrastructure or account changes?
5. A phishing message reached 80 users. Which services and teams are required?
6. Why should legal and privacy teams be involved in a suspected data breach?
7. What is incident qualification?

8. What is a detection feedback loop?
9. An endpoint was isolated, but active sessions were not revoked. What risk remains?
10. Design a concise service catalogue for a new SOC.

Practical exercise

Design a one-page playbook for a phishing email delivered to multiple users. Identify intake, evidence, automated enrichment, human decisions, containment, supporting teams, closure conditions, metrics, and rollback.

SOC Types and Deployment Models

Separating operational focus from ownership and delivery.

Learning outcomes

- Distinguish operational focus from deployment model.
- Compare threat-centric, compliance-focused, and operational capabilities.
- Compare internal, outsourced, and hybrid/co-managed delivery.
- Analyze control, cost, data residency, and startup speed.
- Select a model using risk, context, and maturity.
- Identify governance requirements for providers.

Why Multiple Types and Models Exist

Organizations differ in size, attack surface, data sensitivity, business criticality, budget, talent, regulatory obligations, geographic distribution, cloud use, and operating hours. A model that works for a small online retailer may be unsuitable for a central bank, hospital, energy operator, or global software company.

Two concepts must be separated. *Operational focus* describes what the capability emphasizes. *Deployment model* describes who owns and operates the people, processes, tools, and data. “Virtual” describes location or distribution and is not automatically synonymous with outsourced ownership.

SOC Types by Operational Focus

The following categories are a practical teaching taxonomy rather than a universal standard. Mature SOC types normally combine them.

Threat-centric capability

A threat-centric capability emphasizes adversary behavior, threat modeling, intelligence requirements, proactive hunting, detection engineering, malware and campaign analysis, and coverage against likely tactics and techniques. It asks who targets the sector, which paths lead to crown-jewel assets, which behaviors may be present without an alert, and how intelligence can become a testable hunt or detection.

Threat-hunting hypothesis. “If a ransomware affiliate obtained domain credentials, it may use remote services or legitimate administration tools from workstations that do not normally access file servers.” The hunter searches authentication, endpoint, SMB, RDP, and flow data for that behavior.

Threat modeling links critical assets, attack paths, trust boundaries, exposures, likely actors, preventive controls, detections, and response options. Threat-actor tracking should not become unsupported attribution. It links observed infrastructure, malware, and techniques to known reporting with an explicit confidence level.

Compliance-focused capability

A compliance-focused capability emphasizes policy evidence, audit trails, configuration baselines, log retention, access reviews, separation of duties, control monitoring, and regulatory reporting. It asks whether logging is enabled on critical systems, whether retention and access meet policy, whether changes are authorized, and whether evidence can be produced reliably.

CIS Controls v8.1 provides an actionable set of safeguards covering inventory, secure configuration, account and access management, vulnerability management, audit logs, incident response, and other defensive priorities.^[11] Compliance evidence is valuable, but passing an audit does not prove that advanced threats are detected or that the organization can contain an active incident.

Operational capability

An operational capability focuses on protecting the organization's assets and services through continuous monitoring, alert triage, incident handling, identity and access monitoring, endpoint and network operations, containment, eradication, and recovery. It asks what the organization owns, which services are critical, what normal behavior looks like, and how the team will stop damage and restore operations.

Many organizations begin by building this foundation, add compliance evidence in parallel, and mature toward threat hunting and detection engineering as telemetry, asset inventory, and analyst skill improve.

Table 3-1. SOC types by operational focus

Focus	Core question	Typical outputs	Key skills	Single-focus risk
Threat-centric	How will likely adversaries behave, and what are we missing?	Hunts, threat models, detections, TTP coverage, intelligence assessments	ATT&CK, CTI, malware, analytics, detection engineering	Advanced hunting without reliable telemetry or basic operations
Compliance-focused	Do controls meet requirements, and can we prove it?	Evidence, findings, baselines, reports, corrective actions	GRC, audit, policy, logging, data governance	Paper compliance without effective detection and response
Operational	What do we protect, what is happening, and how do we respond?	Alerts, incidents, containment, recovery, service reports	SIEM, EDR, identity, network, IT, incident response	Reactive operations without proactive searching or strategic improvement

A practical maturity path

- 1. Operational foundation:** asset and log coverage, monitoring, triage, incident ownership, containment, and recovery.
- 2. Governance and compliance in parallel:** policy, evidence, retention, roles, regulatory reporting, and control validation.
- 3. Threat-centric maturity:** threat modeling, intelligence requirements, hunting, detection engineering, attack simulation, and coverage measurement.

This is not a mandatory sequence. It is a guardrail against investing in sophisticated hunts while critical assets are unknown, endpoint coverage is incomplete, or identity logs are unavailable.

Deployment Models

SOC deployment models



“Virtual” describes location and distribution; it is not synonymous with outsourced ownership.

Figure 3-1. Internal/dedicated, outsourced/MSSP, and hybrid/co-managed SOC deployment models. “Virtual” describes distribution and location; it does not by itself define ownership.

Internal or dedicated SOC

The organization owns the team, processes, tools, decisions, and data. Advantages include deep business knowledge, strong control over evidence and residency, high customization, rapid internal coordination, and long-term institutional learning. Challenges include high establishment and operating cost, recruiting difficulty, 24/7 staffing, integration work, training, platform availability, disaster recovery, and full accountability for outcomes.

It is appropriate when data is highly sensitive or sovereign, systems are complex and critical, customization is essential, onsite response matters, and the organization can sustain the required budget and expertise.

Outsourced SOC, MSSP, or MDR service

A provider supplies monitoring, triage, managed detection and response, SIEM engineering, or specialist services under contract. It can offer faster startup, ready expertise, scalable coverage, and 24/7 operations without immediately building a complete internal team.

Risks include limited internal context, data and access sharing, delayed escalation, dependence on contractual scope, inconsistent severity definitions, restricted customization, provider priority conflicts, weak knowledge transfer, and difficult exit. Controls should include data-processing and residency terms, least-privilege access, named contacts, RACI and SLA, quality metrics, audit rights, incident ownership, evidence handling, subcontractor controls, and data return or deletion.

Hybrid or co-managed SOC

A hybrid model combines internal ownership with a provider or external specialists. A provider may monitor after hours or handle Tier 1, while the organization retains incident command, containment decisions, sensitive use cases, regulatory reporting, and system context. It can close 24/7 and advanced-skill gaps while building internal capability.

Hybrid is not automatically “the best of both worlds.” It can create overlapping cost, duplicated tools, responsibility gaps, inconsistent case records, and knowledge loss. It succeeds only with a clear target operating model, shared playbooks, unified severity and metrics, common case management, tested escalation, planned knowledge transfer, and an explicit long-term role or exit path.

Table 3-2. Deployment model comparison

Criterion	Internal / dedicated	Outsourced / MSSP	Hybrid / co-managed
Data control	Highest; organization retains custody and access decisions	Depends on architecture, contract, and provider location	High when sensitive data and decisions remain internal
Environment knowledge	Deep and continuously available	Requires structured context transfer and current asset data	Shared; internal team provides context
Startup speed	Usually slowest	Usually fastest	Medium to fast
Customization	Highest	Contract and platform dependent	Relatively high with clear governance
24/7 coverage	Expensive to staff internally	Often included or scalable	Distributed across internal team and provider
Incident ownership	Internal by design	Must remain explicitly assigned to the customer or agreed provider role	Internal command with provider support
Data residency	Easiest to control	Potential legal and architectural challenge	Controllable through split architecture and restricted access
Knowledge building	Strong	Weak unless transfer is required and measured	Good when transfer and joint operations are planned
Long-term cost	High fixed operating cost	Subscription and usage dependent	Can become high without role clarity and consolidation

Factors for Selecting a Model

Organization size and attack surface

Consider users, branches, cloud tenants, applications, internet-facing services, third parties, identities, endpoints, data sources, event volume, and incident frequency. Scale determines required shifts, platform capacity, specializations, and management layers.

Criticality and data sensitivity

Customer, payment, identity, health, government, research, and sovereign data may require internal control, local processing, strict access, or a segmented architecture. A log can contain personal data, secrets, queries, file paths, and security architecture; it is not automatically safe to export.

Risk and threat level

An organization targeted by ransomware, fraud, state-affiliated actors, or supply-chain threats needs deeper detection, faster containment, specialist support, and more extensive evidence than a low-exposure environment.

Regulatory and contractual requirements

Identify requirements for incident reporting, retention, data location, outsourcing approval, audit rights, segregation of duties, evidence, and customer notification. Requirements differ by jurisdiction and sector and should be reviewed by legal and compliance teams.

Total cost of ownership

License price is only one component. Include staff, shifts, management, storage, compute, network, integration, platform availability, training, certifications, threat intelligence, forensic retainers, testing, and exit costs.

Current expertise and 24/7 need

A capable IT team provides valuable system context but is not automatically a SOC. Staff may need development in triage, detection, evidence, threat hunting, communication, and incident command. For out-of-hours operations, determine who reviews critical alerts, who can contain at night, what the real escalation time is, and how handover works.

Constraints on external sharing

- May raw logs, packet data, malware samples, or PII leave the environment?
- Can the SIEM remain internal while the provider receives limited remote access?
- Are masking, tokenization, filtering, or regional processing required?
- Who can download evidence, create queries, or execute response actions?
- How are provider accounts, sessions, and support access monitored?

Model-design interview questions

Internal SOC

- Does risk justify the cost?
- Is 24/7 coverage required?
- Is sustainable talent available?
- Can the organization operate, secure, and recover the platforms?
- Do policy and data sensitivity require internal custody?

Provider-supported SOC

- Which data and actions can the provider access?
- What is the expected escalation and containment time?
- Who owns the incident and communicates externally?
- How will quality, knowledge transfer, and exit be measured?
- What happens if the provider or connectivity is unavailable?

Decision example: a large financial institution starting from zero

Facts: highly sensitive financial and personal data; multiple branches and continuous services; a capable IT team but limited SOC expertise; a previous ransomware incident; a medium first-year budget; and restrictions on exporting raw logs.

Phased decision: establish a governance-controlled hybrid SOC. Internally retain Tier 2 incident handling, incident command, evidence, containment approvals, regulatory reporting, system context, and sensitive platforms. Use a provider for 24/7 monitoring, Tier 1 overflow, selected MDR, detection-content support, and a malware or forensic retainer. Within 24 months, train the internal team, standardize case management and severity, bring high-sensitivity use cases inside, test playbooks, measure cost and quality, and define the long-term target operating model.

Staffing considerations by focus

- **Threat-centric:** threat hunters, detection engineers, intelligence analysts, malware analysts, senior responders, and purple-team or validation skills.
- **Compliance-focused:** GRC and audit specialists, control-monitoring analysts, evidence and reporting skills, and staff who understand log quality.
- **Operational:** Tier 1 and Tier 2 analysts, incident handlers, security engineers, identity, endpoint, network, Windows, Linux, cloud, and application skills.

How does a SOC designer think?

- What mission and measurable outcomes are required?
- Which assets and services are crown jewels?
- What are the five highest-risk scenarios?
- Which decisions, data, and functions must remain internal?
- What can be purchased as a service without transferring accountability?
- Who can authorize containment and external communication?
- How will the organization operate outside business hours?
- What is the maturity plan and exit path from external dependence?

Common mistakes

- Selecting a model because a vendor sells it rather than because it fits risk.
- Building a dedicated SOC without a sustainable hiring and operating plan.
- Outsourcing monitoring without an internal incident owner and system context.
- Ignoring data residency, provider access, evidence handling, or subcontractors.
- Omitting RACI, SLA, common severity, and case ownership in a hybrid model.
- Believing compliance guarantees security.
- Starting threat hunting without telemetry, baselines, or asset coverage.
- Comparing only first-year cost rather than total cost and dependency.

Chapter summary

Operational focus describes what the SOC emphasizes; deployment model describes who owns and operates it. Mature organizations combine operational, compliance, and threat-centric capabilities and choose internal, outsourced, or hybrid delivery according to risk, data, authority, budget, skills, and time. External services can close a defined gap, but responsibility, context, high-impact decisions, and governance cannot simply be outsourced.

Chapter review questions

1. Compare threat-centric, compliance-focused, and operational SOC capabilities.
2. Which deployment model normally offers the greatest data control?
3. Why is a virtual SOC not necessarily an outsourced SOC?
4. What are the principal risks of an MSSP for a financial institution?
5. A large organization has sensitive data, no SOC, and a medium budget. What is a logical starting model?
6. Why does a hybrid SOC require RACI, SLA, and common case management?
7. When is a compliance-focused capability insufficient?
8. How should an organization decide between hybrid and internal delivery over three years?
9. Which costs belong in TCO beyond licenses?
10. Write an executive paragraph explaining the model-selection criteria.

Practical exercise

Assess an organization with 1,500 employees, 20 branches, continuous services, and sensitive financial data. Select a deployment model and provide the reasons, risks, controls, first-year service scope, and a two-year maturity plan.

04

THE ROLES, SKILLS, AND INTERACTIONS THAT TURN TOOLS INTO CAPABILITY

Building an Effective SOC Team

Clear responsibility, sustainable staffing, and structured knowledge overlap.

Learning outcomes

- Explain Tier 1, Tier 2, Tier 3, and SOC management responsibilities.
- Describe extended engineering and specialist roles.
- Apply role interaction during a major incident.
- Distinguish IOAs from IOCs.
- Design shift coverage and handover.
- Reduce alert fatigue, burnout, and knowledge silos.

Why People Are More Important Than Tools

An organization may own SIEM, EDR, firewalls, threat intelligence, and automation platforms, but tools do not automatically know the business value of a service, distinguish maintenance from malicious behavior, interpret incomplete evidence, or decide when stopping a critical system is justified. Value appears when qualified people work through clear responsibilities, authorities, workflows, and feedback.

Staffing means more than filling job titles. It includes required skills, headcount, operating hours, task distribution, escalation, response authority, training, mentoring, career progression, absence coverage, documentation, and mechanisms that reduce fatigue.

The holistic team

The traditional Tier 1, Tier 2, and Tier 3 model is useful for teaching but not universal. Titles vary, and smaller teams may combine duties. A holistic team creates controlled overlap so analysts can learn, support each other, and avoid dependence on one expert. Overlap does not remove accountability; written responsibilities and escalation remain essential.

Core SOC roles and responsibility layers

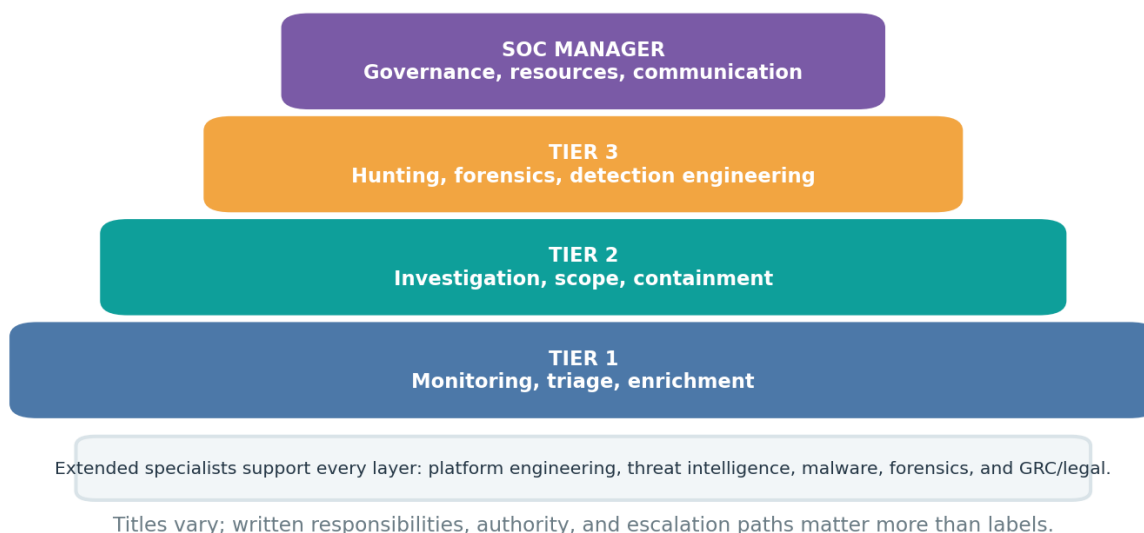


Figure 4-1. Core SOC roles and responsibility layers. Titles vary, but monitoring, investigation, specialist analysis, governance, authority, and communication must be assigned.

Tiered Roles and Extended Specialists

Tier 1: triage and enrichment

Tier 1 is the operational entry point for most alerts. It monitors the queue and sensor health, performs initial triage, enriches alerts with user, device, asset, vulnerability, and reputation context, compares behavior with a baseline, assigns initial severity and priority, documents queries and evidence, closes false or benign positives when justified, escalates cases that require deeper analysis, and activates an approved fast-containment path when conditions are met.

Required foundations

- Networking, Windows, Linux, cloud, and identity fundamentals.
- SIEM search, EDR navigation, ticketing, and documentation.
- Authentication, Active Directory or identity-provider concepts.
- Basic scripting, structured query thinking, and reputation analysis.
- Clear written and verbal communication.

Certification context. CISSP is normally an experienced-practitioner certification with professional-experience requirements; it should not be treated as a prerequisite for an entry-level Tier 1 role. Practical capability and foundational learning matter more at the start.^[20]

Tier 2: incident handling and scope

Tier 2 turns suspicion into a technical understanding that supports response. It gathers telemetry not collected during initial triage, correlates endpoint, identity, network, application, database, and cloud evidence, reconstructs timeline and scope, identifies affected data and services, recommends or coordinates containment, supports eradication and recovery, extracts actionable indicators and behaviors, returns findings to detections, and escalates specialized or complex analysis.

Tier 2 asks how the activity began, whether the adversary moved laterally, which other identities or systems are involved, whether exfiltration occurred, whether the asset is critical, and which response is both effective and proportionate.

Tier 3: threat hunting and senior response

Tier 3 represents the most experienced generalist or subject-matter expertise in the tier model. Responsibilities may include proactive hunting, threat modeling, advanced incident response, detection engineering, malware and artifact analysis, root-cause analysis, complex forensics coordination, attack-path review, and technical leadership during major incidents.

Tier 3 does not wait only for escalation. It works from hypotheses: Were remote services used from devices that never normally use them? Did service accounts perform interactive logons? Is low-volume beaconing present without a rule? Which likely techniques are not covered by current telemetry?

SOC manager and incident manager

The SOC manager is responsible for operations, governance, quality, staffing, training, shift and on-call coverage, performance development, workload, budget, tools, suppliers, metrics, playbooks, audit support, burnout reduction, and communication with the CISO and management. During a major incident, the manager may serve as incident manager or appoint one.

The incident manager coordinates scope, resources, decisions, communications, reporting cadence, and stakeholder tasks. The technical lead ensures the quality of evidence and technical decisions. Separating these roles in a major case prevents communication and administration from consuming the technical lead's attention.

Extended roles

CISO

Defines security strategy and risk appetite, aligns the SOC with business needs, obtains resources, and reports to senior management.

SIEM or platform engineer

Onboards sources, manages parsers and normalization, platform health, HA/DR, RBAC, retention, integrations, and rule deployment.

Detection engineer

Designs, tests, deploys, tunes, versions, and measures detections; maps coverage and incorporates incident findings.

Threat intelligence analyst

Defines intelligence requirements, evaluates source reliability and confidence, produces relevant context, and supports hunting and detection.

Digital forensics specialist

Preserves evidence, acquires disk or memory, reconstructs timelines, analyzes artifacts, and maintains chain of custody.

Malware analyst

Performs static and dynamic analysis, identifies behavior, C2, and persistence, and develops signatures or detection content.

GRC and legal liaison

Connects incident response with policy, risk, privacy, evidence requirements, regulators, and authorized external communication.

Security engineer

Implements endpoint, network, identity, cloud, email, and hardening controls and supports recovery and validation.

IOA and IOC

An indicator of attack focuses on behavior or intent, such as credential dumping followed by remote logon, encoded scripting that disables controls, unusual service-account use, lateral movement, or mass encryption. An indicator of compromise is an artifact associated with compromise, such as a file hash, malicious domain, ransom note, registry value, certificate, or known infrastructure.

Table 4-1. Comparison of indicators of attack and indicators of compromise

Dimension	IOA	IOC
Focus	Behavior, sequence, objective, or intent	Known artifact, observable, or infrastructure
Example	Credential dumping followed by remote administrative access	Malware hash or C2 address
Value	Can detect early and adapt when infrastructure changes	Useful for enrichment, blocking, scoping, and hunting
Limitation	Requires context, telemetry, and analysis	May change, expire, be shared by benign services, or be evaded

The analyst functional model

Security analyst functional model



The same analyst may work across several functions; evidence and authority determine the next action.

Figure 4-2. A security analyst may contribute across prevention, collection, detection, analysis, and mitigation. Evidence and authority determine the next action.

- **Prevent:** firewall, IPS, email, web, endpoint, identity, hardening, and awareness controls reduce likelihood but do not eliminate incidents.
- **Collect:** endpoint, network, identity, cloud, application, database, and business telemetry provide evidence; an offline sensor creates a blind spot.
- **Detect:** rules, signatures, analytics, and hunts produce signals.
- **Analyze:** SIEM, EDR, flow, PCAP, sandbox, identity, database, and forensic sources support validation and scope.
- **Mitigate:** isolation, blocking, account restriction, configuration change, and recovery reduce impact under defined authority.

Role toolsets

- **Tier 1:** SIEM dashboards and search, case management, EDR console, email security, basic CTI lookup, CMDB, and identity directory.

- **Tier 2:** advanced SIEM queries, EDR investigation, identity and network logs, sandbox, vulnerability context, flows, and PCAP.
- **Tier 3:** hunting platforms, forensic tools, memory and disk analysis, malware analysis, packet analysis, ATT&CK, CTI, and detection engineering.
- **Management:** queue, SLA, shift, coverage, quality, training, incident, risk, supplier, and executive-reporting views.

Role Interaction During a High-Impact Ransomware Incident

The HR director reports a ransom note and unreadable files. At the same time, endpoint and network telemetry show a suspicious process and beaconing from the same device.

Tier 1

- Correlates the report and alert, identifies the user and asset, determines criticality, opens the incident, preserves initial evidence, and escalates immediately.
- Activates the approved containment path when the confidence and impact criteria are met.

Tier 2

- Analyzes endpoint and network behavior, process tree, file changes, identity activity, and nearby events.
- Identifies likely C2 and affected resources, determines scope, and coordinates isolation and account restriction.

Tier 3 and specialists

- Verify effective isolation; hunt across the environment; review lateral movement, credential access, persistence, and exfiltration; analyze artifacts; and create new detections.

SOC or incident manager

- Declares a major incident when criteria are met, separates technical and coordination roles, distributes tasks, preserves routine monitoring, communicates with CISO, HR, legal, IT, and management, and tracks decisions and update times.

IT, NOC, identity, and endpoint teams

- Execute isolation, blocking, session termination, account restriction, endpoint control deployment, rebuilding, patching, staged recovery, and validation.

The investigation reveals that endpoint protection had not reached part of HR. Corrective actions therefore include a verified deployment target, an asset-coverage dashboard, controls that prevent unmanaged devices, and an updated ransomware playbook.

Burnout, Staffing, and Handover

Burnout and alert fatigue

Burnout is an operational risk, not a personal weakness. Causes include excessive noise, repetitive work, shift disruption, inadequate staffing, high responsibility with little authority, poor documentation, continuous crisis exposure, lack of recognition, and limited development.

Practical controls

- Reduce noise through detection tuning, suppression with governance, context, and safe automation.
- Balance shifts, on-call load, rest, leave, and recovery time after major incidents.
- Rotate staff between monitoring, investigation, hunting, engineering, documentation, and training.
- Provide mentoring, psychological safety, blameless review, career paths, and a learning budget.
- Document critical knowledge and cross-train so one expert is not a single point of failure.
- Measure queue and quality at team and system level rather than rewarding raw ticket closure.

Designing shift coverage

There is no universal analyst-to-alert ratio. Calculate coverage hours, alert arrival by severity and time, triage duration, escalation rate, major-incident demand, administrative and engineering work, leave, training, absence, and the amount of work that cannot be automated. Not all employee time should be counted as alert-processing time; research, documentation, exercises, and improvement are part of the service.

Shift handover

- Open incidents, severity, owner, current state, and next update.
- Confirmed facts versus hypotheses.
- Completed actions, pending tasks, approvals, and rollback state.
- Evidence locations, queries, artifacts, and integrity notes.
- Stakeholders, contacts, business risks, and watch items.

The case-management system should be the source of truth. Private chat may accelerate coordination but must not become the only record of evidence, decisions, or pending tasks.

How does a team member think?

- What is my responsibility and authority in this case?
- Is the case within my skill level, or must I escalate or request an SME?
- Is the threat active, and have I collected the minimum context?
- Should fast containment be executed, proposed, or withheld?
- Have I recorded what I did, why, and with what result?
- What could be lost during the next shift change?
- How will this knowledge return to the team?

Common mistakes

- Treating Tier 1 as a button-clicking role without analytical responsibility.
- Tier 1 retaining a complex case too long or escalating routine cases without enrichment.
- Relying on titles rather than written responsibilities and authority.
- Ignoring sensor health and platform delay when judging analysts.
- Making one expert the only source of knowledge.
- Failing to separate incident coordination from technical leadership.
- Measuring performance only by tickets closed.
- Ignoring burnout, absence, and training in staffing calculations.

Chapter summary

An effective SOC distributes work from monitoring and triage to investigation, threat hunting, engineering, incident command, and governance. Tier 1 enriches and qualifies; Tier 2 determines scope and coordinates response; Tier 3 handles advanced analysis and proactive improvement; and management ensures sustainable resources, authority, quality, and communication. Tools enable the team but do not replace judgment. Sustainability requires clear roles, handover, training, automation, fair staffing, and knowledge transfer.

Chapter review questions

1. Who normally performs initial alert triage?
2. What is the practical difference between Tier 2 and Tier 3?
3. What does the SOC manager do during a major incident?
4. Tier 1 observes encoded scripting and an external connection. What enrichment is required?
5. What is the difference between an IOA and an IOC?
6. Which operational factors contribute to burnout?
7. Why is structured knowledge overlap valuable?
8. Who should decide whether to isolate a domain controller?
9. List typical tools used at each tier.
10. Propose three policies that reduce burnout without reducing coverage.

Practical exercise

Create a RACI for a privileged-account compromise involving Tier 1, Tier 2, Tier 3, the incident manager, identity, NOC, system owner, legal, and management. Ensure that each task has one accountable role.

Security Event Data and Analyst Tools

From raw telemetry and alerts to a defensible incident story.

Learning outcomes

- Distinguish session, transaction, packet, artifact, statistical, alert, and external data.
- Map attack questions to data sources and tools.
- Explain SIEM, EDR, XDR, NDR, NSM, and case management.
- Use correlation to build a timeline and scope.
- Preserve evidence and recognize tool limitations.
- Manage data quality, retention, and time synchronization.

Golden Rule: Start with the Question, Not the Tool

No single console answers every incident question. An analyst may need to know who communicated with whom, what process executed, which identity authenticated, what data was read, whether a file was transferred, who received an email, whether a weakness was exploited, or whether an action was authorized. Each question leads to a different data type and source.

Mature investigation thinking. Do not begin with “Which console should I open?” Begin with “What hypothesis am I testing? What evidence would support or refute it? Where should that evidence exist, and what can the source not prove?”

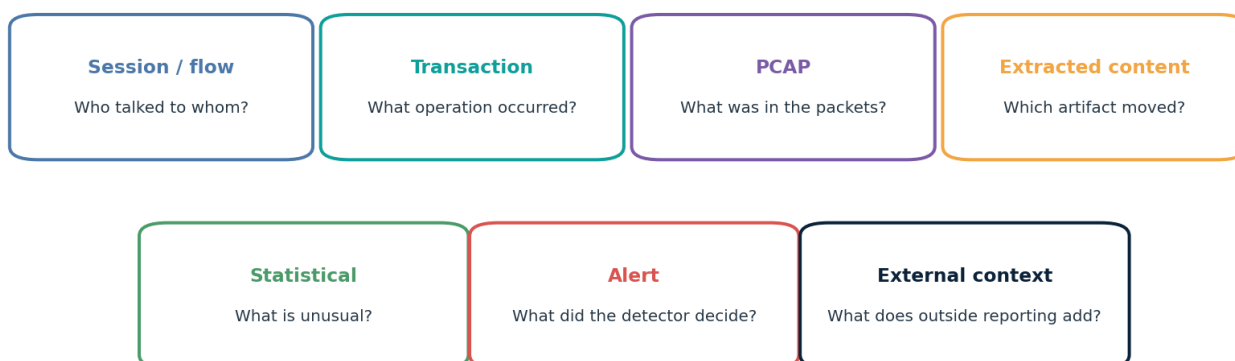
Sources of security telemetry

- **Endpoint:** process trees, command lines, files, registry, memory, network connections, user context, and isolation status.
- **Identity:** logons, MFA, tokens, group changes, privileged access, service accounts, and risk signals.
- **Network:** firewall, IDS/IPS, NetFlow/IPFIX, DNS, proxy, TLS metadata, NDR, and PCAP.
- **Email and collaboration:** headers, message trace, attachments, URLs, clicks, sender reputation, and internal forwarding.
- **Applications and databases:** authentication, transactions, queries, exports, errors, administrative actions, and schema changes.
- **Cloud and SaaS:** API calls, sign-ins, resource creation, permission changes, object access, and control-plane activity.
- **Security systems:** alerts, findings, risk scores, sensor status, vulnerabilities, and response actions.
- **People and external parties:** user reports, helpdesk, suppliers, researchers, customers, and other response teams.

Investigation quality depends on coverage, parsing, context, time, retention, and source health as much as it depends on analyst skill.

Network and Security Data Types

Security event data types answer different questions



A complete incident picture normally combines several types.

Figure 5-1. Security event data types answer different investigative questions. A complete incident picture normally combines several types.

Session or flow data

Session data summarizes communication between endpoints. It resembles a telephone bill: who communicated, when, for how long, over which protocol, and how much data moved, but not necessarily what the conversation contained. The common five-tuple is protocol, source IP, source port, destination IP, and destination port. Additional fields may include start and end time, packets, bytes, interfaces, direction, and TCP flags. NetFlow, IPFIX, and related export formats are common sources.

Flow data can reveal beaconing, unusual east-west communication, large transfers, top talkers, unexpected ports, and lateral movement. It cannot by itself prove the initiating process, the user's intent, the file content, or whether encrypted traffic was malicious.

Transaction data

Transaction data describes an operation within a service or system. One network session may contain multiple transactions, and local transactions may occur without a visible network session. Examples include HTTP requests and responses, DNS queries, SMTP delivery and message IDs, database queries, file access, logon events, cloud API calls, and application actions. Transaction formats vary, so normalization must preserve the original evidence and important fields.

Full packet capture

PCAP contains packet headers and, when available, payload. It supports deep protocol analysis, session reconstruction, metadata review, and extraction of unencrypted content. Limitations include high storage and compute cost, privacy and legal restrictions, limited retention, and encryption. A practical method is to narrow the time, addresses, ports, and session using alerts and flow before opening the relevant packet capture.

Extracted content and artifacts

Extracted content may include downloaded executables, scripts, email attachments, certificates, DNS names, strings, archives, and documents. Suspicious artifacts should be stored in an isolated evidence location, hashed, labeled, and linked to their source. Analysts should never open or execute them on an ordinary workstation.

Statistical and behavioral data

Statistical data aggregates events to reveal baseline, periodicity, volume, relationships, and deviation. A single small C2 connection may look harmless, but a graph that shows a same-size connection every 60 seconds can indicate beaconing. An anomaly remains a hypothesis; business schedules, backups, monitoring tools, and service behavior must be considered.

Alert data

An alert is a judgment from a rule, signature, model, or analytic. It reduces millions of observations into a manageable signal but may be a true positive, false positive, benign positive, or incomplete summary. False negatives do not appear in the queue. An alert is therefore an investigation starting point, not the final evidence.

External context

External data includes vulnerability advisories, intelligence reports, campaign analysis, indicators, TTPs, reputation, certificate history, domain age, and sector warnings. Evaluate source reliability, confidence, recency, relevance, and sharing restrictions. An address in a feed does not prove compromise, especially when it belongs to a shared cloud or content-delivery service.

Table 5-1. Comparison of security event data types

Type	Primary question	Best use	Main limitation
Session / flow	Who communicated with whom, when, and how much?	Beaconing, transfer volume, lateral movement, traffic relationships	Does not show content or initiating process
Transaction	What operation occurred in a service?	HTTP, SMTP, DNS, database, login, file, and cloud activity	Formats and semantic detail vary
PCAP	What were the packet and protocol details?	Deep network analysis, reconstruction, extraction, evidence	Storage, privacy, encryption, and limited retention
Extracted artifact	What file, certificate, or object was involved?	Malware analysis, sandbox, forensics, scoping	Execution risk and evidence-handling requirements
Statistical	What is normal, related, or anomalous?	Baseline, trends, periodicity, relationship analysis	An anomaly is not automatically an incident
Alert	What judgment did a detector make?	Triage and prioritization	False positives, false negatives, and missing context
External	What outside context is available?	Enrichment, hunting, vulnerability and campaign context	Can be outdated, irrelevant, or restricted

Linking data to attack activity

Table 5-2. Attack activities and useful data sources

Activity	Example	Useful data
Reconnaissance	Scanning and enumeration	Firewall, WAF, IDS, web, cloud edge, and external exposure data
Delivery and initial access	Malicious message, download, stolen identity, exposed service	Email headers, message trace, proxy, DNS, identity, VPN, WAF, application, and endpoint data
Execution and exploitation	Script or vulnerable service execution	EDR, process and command line, application, WAF, IDS/IPS, memory, vulnerability context
Persistence and privilege	Scheduled task, token, service, group change	Endpoint, registry, services, identity, PAM, cloud control-plane logs
Command and control	Beaconing or external command channel	Flow, DNS, proxy, firewall, TLS metadata, PCAP, endpoint connections
Lateral movement	SMB, RDP, remote services, admin tools	Identity, endpoint, Windows events, flow, network and service logs
Objectives	Exfiltration, encryption, fraud, destruction	Database, DLP, file access, endpoint, flow, application transactions, backup and cloud logs

MITRE ATT&CK provides a detailed behavior-based language for tactics and techniques. It is most useful when it connects observations to hypotheses, coverage, testing, and response - not when it is used merely as an incident label.^[6]

A method for selecting the tool

Question-led investigation method



What happened? What evidence would confirm it? Where is that evidence? Which tool retrieves it? What action follows?

Start with the investigative question, not the console.

Figure 5-2. A question-led investigation method: define the hypothesis and evidence before selecting a console or tool.

Did a suspicious login occur?

Use identity-provider, VPN, MFA, Active Directory, PAM, UEBA, device, user schedule, and change data.

What happened on the endpoint?

Use EDR/XDR, process tree, command line, files, registry, network connections, Sysmon, memory, and forensic artifacts.

Was there external communication or exfiltration?

Use firewall, proxy, DNS, flow, NDR, DLP, endpoint process context, and targeted PCAP.

Is a file malicious?

Use hashing, static analysis, approved reputation, sandbox, endpoint behavior, memory, and a malware analyst. No single verdict is absolute.

Does a vulnerability exist?

A scanner shows potential weakness. Application, endpoint, IDS, WAF, memory, and other evidence are needed to confirm exploitation.

Was the action authorized?

Use change records, job schedules, ITSM, the system owner, the data owner, and the initiating identity or service.

SIEM, EDR, NDR, NSM, and Analysis Tools

SIEM

SIEM collects, parses, normalizes, indexes, correlates, searches, alerts, enriches, retains, and reports on security data. It provides broad visibility and a common analytical layer, but it sees only the telemetry forwarded to it. It does not automatically understand business context, preserve every original detail, or stop threats unless integrated with response controls. Alert quality depends on logs, parsing, rules, sizing, and governance.

ITSM and security case management

Case management organizes incident ID, owner, status, severity, SLA, tasks, approvals, timeline, evidence links, communication, and closure. Important decisions should not remain scattered across email and private chat. Security-oriented case platforms such as TheHive focus on cases, tasks, observables, collaboration, and integration with analyzers and responders.^[17]

EDR, XDR, and NDR

- **EDR:** endpoint process and parent-child relationships, command lines, files, registry, connections, user context, searches, isolation, and response.

- **XDR:** correlates multiple domains such as endpoint, identity, email, network, and cloud. Integration depth, ownership, retention, and response authority still require examination.
- **NDR:** focuses on network behavior such as east-west traffic, unknown devices, beaconing, lateral movement, and exfiltration.

IDS/IPS: Snort and Suricata

Rules-based network engines can alert on or block matching traffic. Review the rule, version, protocol, source and destination, whether the destination is vulnerable, whether traffic was delivered or blocked, supporting PCAP or Zeek logs, and endpoint evidence. A signature match without context may be a scan, a failed attempt, a false positive, or a genuine exploitation path.

Zeek

Zeek analyzes protocols and produces structured transaction and metadata logs such as connection, DNS, HTTP, TLS, files, SMTP, and notices. It supports threat hunting and protocol analysis even when a ready-made signature does not fire. Log names and fields depend on version and configuration.

Security Onion

Security Onion 2.4 is an integrated network security monitoring and log-management platform that combines network metadata, detections, packet visibility, endpoint or agent data, search, dashboards, and case-oriented analysis. Architecture and included components evolve, so current official documentation should be used for design and deployment.^[15]

Historical components. Older training material may mention ELSA, Sguil, Squert, or earlier Elastic-stack designs. They remain useful for understanding platform evolution but should not be assumed to describe the current release.

Elastic, Wazuh, Sysmon, and syslog

- **Elasticsearch:** indexing, search, and aggregation.
- **Logstash or equivalent pipelines:** ingestion, parsing, transformation, and routing.
- **Kibana or equivalent:** search, visualization, and dashboards.
- **Wazuh:** host monitoring, file integrity, logs, and compliance-oriented functions.
- **Sysmon:** detailed Windows process, network, file, registry, and related telemetry when configured appropriately.
- **syslog-ng and other collectors:** receive, filter, transform, and route syslog data.

Wireshark, NetworkMiner, and CyberChef

Wireshark supports protocol and packet analysis; NetworkMiner supports host, session, and artifact extraction from captures; CyberChef supports decoding, encoding, parsing, transformation, and hashing. Sensitive data should not be uploaded to an unapproved public instance.

Flow and network analytics

Flow analytics can reveal beaconing, DDoS, lateral movement, insider activity, unusual services, and data exfiltration. “22 GB to an external destination” is not a conclusion. The analyst still needs the asset owner, business schedule, initiating process and account, destination context, data accessed, and change record.

Malware sandbox

A sandbox executes an artifact in an isolated environment and records process, file, registry, persistence, dropped files, network connections, and behavior. Malware may detect the sandbox, wait for user interaction, require unavailable dependencies, or delay execution. The verdict must be combined with endpoint, network, identity, intelligence, and forensic evidence.

Threat intelligence platforms

Threat intelligence platforms support indicator lookup, STIX/TAXII exchange, watchlists, campaign and actor context, source tracking, confidence, and sharing restrictions. Intelligence should answer defined requirements. Collecting thousands of irrelevant indicators adds noise without improving defense.

Vulnerability assessment and penetration testing

A vulnerability assessment identifies known weaknesses and misconfigurations and prioritizes remediation. A penetration test is an authorized assessment that attempts to validate exploitability and impact under a defined scope, rules of engagement, safety plan, and rollback. A vulnerability is potential exposure; exploitation requires evidence. Prioritization should consider asset criticality, exposure, threat intelligence, exploitation evidence, compensating controls, business owner, and patch availability - not CVSS alone.

Forensics and evidence

Evidence can include disk and memory images, logs, packet captures, email headers, hashes, screenshots, physical-access records, and cloud audit data. When evidence may support legal, regulatory, disciplinary, or insurance processes, integrity, documentation, acquisition method, time, access, and chain of custody matter. NIST SP 800-86 describes the integration of forensic techniques with incident response.^[18]

Correlation, Data Quality, and Evidence

Building the incident story

Email gateway: malicious attachment delivered
EDR: spreadsheet spawned encoded scripting
DNS: newly observed domain queried
Firewall: outbound encrypted connection
Identity: unusual privileged login
File server: mass SMB writes
Backup system: failed administrative authentication

Each source answers part of the question. Temporal and contextual correlation converts isolated events into a probable attack story and reveals which gaps must be tested.

Data quality

- Missing fields, parser failures, duplicate events, and inconsistent schemas.
- Time skew, timezone mistakes, and delayed ingestion.
- Incorrect host, user, IP, or asset mapping.
- Log drop, queue backlog, sensor offline, or sampling.
- Permissions that prevent analysts from accessing original evidence.

Retention and time synchronization

Retention should align with expected dwell time, legal and regulatory needs, threat-hunting requirements, privacy and minimization, cost, and the availability of hot, warm, or archive search. Short retention may erase initial access and reconnaissance before detection. Reliable NTP and timezone normalization are essential; differences of minutes or hours can corrupt a timeline and lead to an incorrect conclusion about which internal system acted first.

Scenario: 22 GB from DB-REPORT01

Alert: Large outbound transfer
Host: DB-REPORT01
User: svc_report
Destination: External address
Data: 22 GB
Time: 03:10

Table 5-3. Mapping investigation questions to sources and tools

Question	Primary source	Tool or function
Is there a legitimate scheduled job or approved change?	Scheduler, change record, application owner	ITSM, application logs, interview
What data was read or exported?	Database audit and application transaction logs	Database platform, SIEM
Which process initiated the connection?	Endpoint telemetry	EDR, process tree, memory if required
Where did it go and how much moved?	Flow, firewall, proxy, DNS	NDR, SIEM, network tools
What is known about the destination?	Threat intelligence, registration and certificate history	Approved intelligence platform
Was the service account used elsewhere?	Identity, PAM, VPN, cloud and authentication logs	SIEM, UEBA, identity console
Is the transfer still active and can it be stopped safely?	Flow, DLP, endpoint, system owner	NDR, DLP, EDR, incident workflow

If the transfer has no legitimate explanation and remains active, contain it according to the play-book while preserving evidence. Depending on business impact, the action may block the destination, terminate the connection, isolate the host, restrict the account, or stop a job. The team should verify the result and document the decision.

How does the analyst think?

- What question am I answering, and which data type can answer it?
- Am I seeing original data, normalized data, an alert summary, or a vendor verdict?
- Is time reliable and the source healthy?
- What can this source not prove?
- What independent source can confirm or refute it?
- Are privacy, legal, contractual, or evidence restrictions relevant?
- Must an artifact be preserved before a response action changes it?
- Which blind spot could explain missing evidence?

Common mistakes

- Using SIEM for every question.
- Treating flow as packet content or an alert as raw evidence.
- Opening broad PCAP without narrowing time and session.
- Relying on one indicator, reputation score, or sandbox verdict.
- Confusing vulnerability with exploitation.
- Ignoring encryption while overlooking useful metadata.
- Collecting logs without use cases, owners, health monitoring, or retention.
- Executing artifacts outside an isolated environment.
- Failing to record queries, timestamps, evidence locations, and limitations.

Chapter summary

A defensible investigation begins with a hypothesis and question, then selects the data type, source, and tool that can answer it. Session, transaction, packet, endpoint, identity, artifact, statistical, alert, and external data complement one another. SIEM correlates broad telemetry; case management organizes the record; EDR, NDR, NSM, application, database, intelligence, and forensics add depth. Coverage, parsing, time, retention, health, and evidence handling determine whether the SOC sees reality or only a partial representation.

Chapter review questions

1. What are the five elements of the network five-tuple?
2. Which data type resembles a telephone bill?
3. What is the difference between session and transaction data?
4. When should full packet capture be used?
5. A connection occurs every 60 seconds with a similar size. Which data types are useful?
6. Why is alert data not automatically the most accurate source?

7. What is the conceptual role of Security Onion?
8. How do vulnerability assessment and penetration testing differ?
9. Which sources are needed for a suspected database exfiltration?
10. Explain why the investigation question comes before tool selection.

Practical exercise

For a 25 GB transfer from a database server, write the hypotheses and questions, map each to evidence and tools, identify containment options and approvals, and define what would confirm a benign scheduled export versus unauthorized exfiltration.

Relationships with Stakeholders

The right information, to the right party, at the right time, through the right channel.

Learning outcomes

- Identify internal and external incident stakeholders.
- Define their responsibilities and decision rights.
- Use FIRST and NIST guidance to structure coordination.
- Create an incident communication plan.
- Apply RACI, TLP, need-to-know, and out-of-band channels.
- Communicate during a business crisis without speculation.

Why Relationships Are Part of Security Capability

The SOC does not possess every skill or authority required to respond. It may detect ransomware, but it needs IT or NOC to isolate infrastructure, identity staff to restrict an account, a system owner to explain the impact of stopping a service, legal and privacy to assess obligations, management to make a business decision, and suppliers or providers to assist with external systems.

Relationships, contact channels, service expectations, and approval paths are therefore incident response controls. If they are created during the crisis, delays, contradictory action, and uncontrolled disclosure are likely.

Communication rule. Provide the right information to the right party at the right time, through a secure approved channel, with a clear action or decision request.

Internal and External Stakeholders

A stakeholder is a person, team, or organization affected by the incident or holding information, authority, a decision, a service, or an obligation related to it.

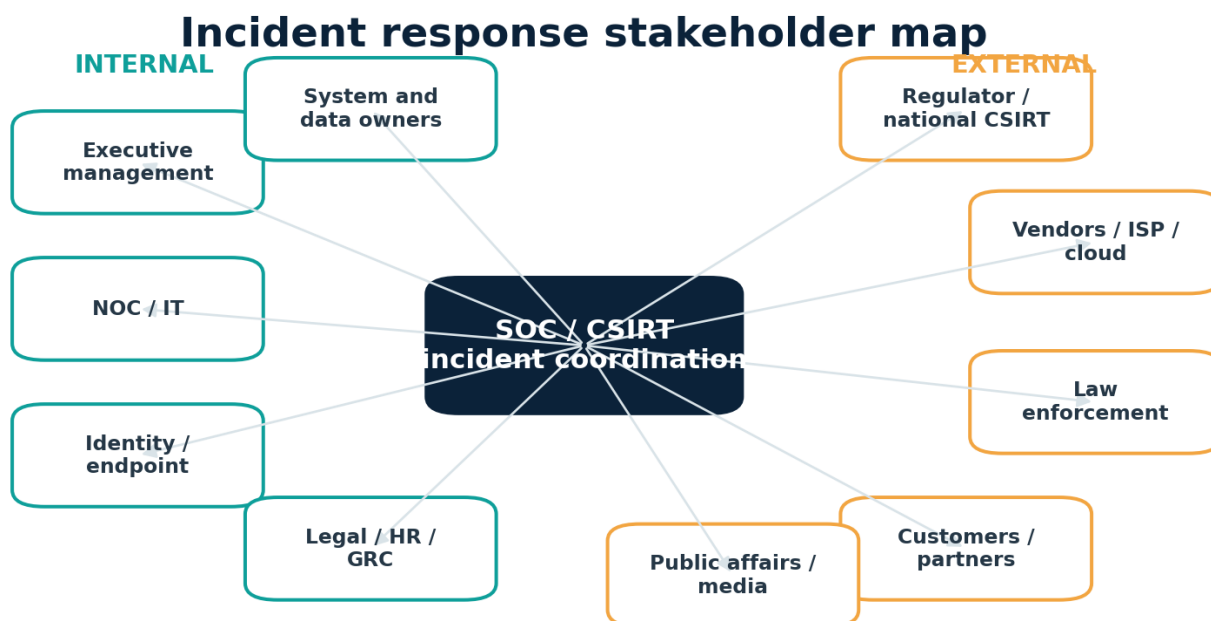


Figure 6-1. Internal and external stakeholders around SOC/CSIRT incident coordination. The exact parties depend on the organization, sector, jurisdiction, and incident.

Executive management

Management sets policy, budget, priority, risk acceptance, and the balance between service continuity and protection. Executive updates should focus on business impact, affected services and data, actions completed, decisions required, remaining risks, confidence, and the time of the next update.

CISO and CIO

The CISO focuses on security strategy, governance, risk, regulatory impact, and security decisions. The CIO focuses on technology services, availability, resources, dependencies, and recovery. Responsibility may overlap and should be defined rather than assumed.

Incident manager and technical lead

The incident manager coordinates people, tasks, decisions, communications, and reporting. The technical lead ensures the quality of investigation, evidence, and technical recommendations. In a major incident, separating them helps preserve attention.

Helpdesk

The helpdesk may be the first point of contact for employees. It should collect user and device details, symptoms, time, screenshots or error messages, and what the user did, then open and route the case. It does not automatically own eradication, patching, or security decisions.

NOC and IT operations

They isolate endpoints or segments, block traffic, stop services, retrieve logs, rebuild or patch systems, restore connectivity, and validate operational impact. The SOC explains the reason, priority, and verification criteria.

System owner, service owner, and data owner

The system or service owner explains function, dependencies, critical periods, acceptable outage, and recovery validation. The data owner determines classification, sensitivity, authorized access, business impact of disclosure or alteration, and notification requirements.

HR

HR joins incidents involving employee data, insider risk, misconduct, disciplinary action, workforce communication, or targeted awareness. Security staff should not confront or monitor employees outside approved policy and legal authority.

Legal, privacy, compliance, and risk

These functions assess monitoring authority, evidence handling, privilege, breach thresholds, regulatory obligations, contracts, external sharing, notifications, risk-register impact, audit evidence, and corrective actions. Legal can guide evidence procedures; it cannot guarantee how a court will evaluate evidence.

Public affairs and media relations

Public affairs manages public messages, approved spokespeople, holding statements, customer communication, and media coordination. A SOC analyst should not speak to the media unless specifically authorized.

Business continuity and disaster recovery

They connect cyber response with business impact analysis, recovery priorities, RTO/RPO, failover, alternate sites, continuity of operations, and crisis management.

Physical security

Physical security may supply badge logs, CCTV, visitor records, device retrieval, site access, or response to an event that combines cyber and physical activity.

External stakeholders

- **Regulators:** receive reports when legal or sector criteria are met, through an authorized process and within defined timeframes.
- **National or sector CSIRT:** may provide warnings, indicators, coordination, situational awareness, and technical support.
- **Law enforcement:** may address cybercrime, fraud, extortion, ransomware, and theft; engagement should occur through authorized contacts and legal coordination.
- **Vendors and PSIRTs:** provide product-specific logs, guidance, patches, hotfixes, vulnerability coordination, and detection information.
- **Cloud providers and ISPs:** may provide logs, preserve snapshots, suspend keys or resources, isolate workloads, perform upstream blocking, or mitigate DDoS.
- **External incident response and forensics:** supply specialist capacity under a retainer that defines response time, access, evidence, scope, reporting, and ownership of findings.
- **Customers and partners:** need accurate, actionable information when their data or services are affected.
- **Researchers and external reporters:** may identify a weakness or report abuse and require a safe intake and acknowledgment process.

FIRST, NIST, and Communication Planning

FIRST CSIRT Services Framework

FIRST organizes CSIRT services into service areas, services, functions, and sub-functions. Current Version 2.1 includes areas such as information security event management, incident management, vulnerability management, situational awareness, and knowledge transfer, supported by organizational services. A CSIRT selects the services that fit its mandate and constituency.^[3]

- **Event management:** monitoring, detection, event analysis, sensor and log management, and detection content.
- **Incident management:** report acceptance, analysis, artifact or forensic analysis, coordination, mitigation, and recovery.
- **Vulnerability management:** discovery, report intake, analysis, coordination, disclosure, and response.
- **Situational awareness:** data acquisition, analysis, synthesis, and communication.
- **Knowledge transfer:** awareness, training, exercises, and technical or policy advice.

NIST update

NIST SP 800-61 Rev. 3 replaced Rev. 2 in April 2025. It integrates incident response into CSF 2.0 risk management. Earlier operational concepts remain useful, but policy and governance should refer to the current revision and current framework.^{[1][2]}

Incident communication plan

An effective plan defines purpose, scope, activation, audiences, roles, points of contact and backups, classification, channels, message approval, templates, escalation, external communication, media handling, training, testing, maintenance, and lessons learned. The CERT/SEI communication guide emphasizes purpose, audience, roles, messaging, channels, and exercised distribution mechanisms.

[5]

Identify each audience

- Tier 2 needs evidence, indicators, hypotheses, and scope.
- NOC needs addresses, systems, required action, urgency, verification, and rollback.
- CISO and management need risk, impact, confidence, decisions, and time to next update.
- Employees need clear protective instructions.
- Customers need the effect on them and practical steps.

Define triggers

Examples include immediate escalation of critical ransomware to the incident manager, CISO, IT, identity, legal, and business owners; large-scale DDoS to the ISP, business continuity, and public affairs; and suspected personal-data compromise to legal, privacy, compliance, and the data owner. The organization must adapt triggers to local law and sector obligations.

Every update should answer

- What happened, and what is confirmed?
- What remains suspected, unknown, or under investigation?
- What is the current business and data impact?
- What actions are complete or in progress?
- What decision or action is required from the recipient?
- When is the next update?

RACI, TLP, Channels, and Crisis Communication

RACI

Responsible performs the work; Accountable owns the decision and outcome; Consulted provides input; Informed needs awareness. A practical RACI normally assigns one accountable role per task. Multiple responsible roles can collaborate, but ambiguous accountability creates delay.

Table 6-1. Example RACI for a ransomware incident

Task	SOC / CSIRT	NOC / IT	Identity	System owner	Legal / privacy	Incident manager / management
Triage, scope, and technical recommendation	R	C	C	C	I	A
Isolate user endpoint	C	R	I	C	I	A
Restrict compromised ordinary account	C	I	R	C	I	A
Stop or restrict a critical service	C	R	C	R	C	A
Assess possible personal-data breach	C	C	C	C	R	A
External regulatory or public communication	I	I	I	C	R	A

The table is illustrative. The organization must tailor accountable roles to its policy, legal obligations, and authority model.

Information sharing and TLP

FIRST Traffic Light Protocol 2.0 defines TLP:RED, TLP:AMBER, TLP:GREEN, and TLP:CLEAR, with TLP:AMBER+STRICT as an additional restriction. TLP tells recipients how information may be shared; it does not replace classification, privacy, law, contract, or need-to-know.^[4]

Transparency does not mean sharing everything. Minimize information to what the recipient requires, considering personal data, legal privilege, investigation integrity, security architecture, vendor restrictions, and the risk of helping the adversary.

Communication channels

Primary channels may include the case platform, corporate email, secure collaboration, telephone, incident portal, and war room. If the domain, identity provider, email, or network is compromised, use tested out-of-band channels such as separate telephones, an approved platform outside the affected environment, in-person coordination, or provider emergency channels. A channel that exists only on paper is not a control.

Executive status update

Incident: INC-2026-017 / Critical

Status: Ransomware confirmed on one finance endpoint; endpoint isolated.

Known impact: One file share affected; no confirmed payment-system impact.

Actions: Account restricted, SMB sessions terminated, hunting in progress.

Decision required: Approve temporary read-only mode for the Finance share.

Unknowns: Data-exfiltration assessment ongoing.

Next update: 30 minutes.

This is more useful than sending raw logs to executives or claiming that “everything was breached” before evidence supports the statement.

Crisis communication

When an incident becomes a business crisis, reporting frequency and decision authority may change. Cyber incident response should connect to crisis communication, business continuity, executive crisis management, customer service, and regulatory notification. Prepare holding statements, FAQs, hotlines, web-update processes, alternate staff, media talking points, and approval paths before the crisis.^[5]

Scenario: suspected exfiltration from the payroll database

```
Host: PAYROLL-DB01
Account: svc_payroll_export
Data: 45 GB
Destination: External cloud storage
Time: 02:20
Change record: None found
```

Internal stakeholders include SOC, DBA and system owner, NOC, identity, HR and the data owner, legal/privacy/compliance, CISO, and management. Potential external stakeholders include the cloud provider for evidence preservation, a regulator if criteria are met, external forensics if specialist support is needed, law enforcement for organized crime, and affected persons according to applicable law and an authorized decision.

Accurate initial message. “A potentially unauthorized 45 GB transfer from the payroll database to an external destination was detected. The connection was stopped and the account restricted. Content and scope are being determined. A personal-data breach has not yet been conclusively confirmed.”

Premature statement. “All employee payroll data was leaked” should not be stated before scope and content are established.

Media and trust

- Assume there is no guaranteed “off the record.”
- Use a small set of approved messages and avoid speculation.
- Explain technical issues in the audience’s language.
- Distinguish known, unknown, suspected, and under investigation.
- Do not disclose sensitive controls, gaps, evidence, or personal information unnecessarily.
- Keep spokespeople aligned and correct inaccuracies promptly.

Testing relationships and the plan

- Call-tree and backup-contact tests.
- Out-of-band communication tests.
- Ransomware and data-breach tabletop exercises.
- Provider emergency escalation and evidence-preservation tests.

- Regulator notification drills where appropriate.
- Media simulation, shift handover, and executive update exercises.

Record failures and improvements as corrective actions with owners and due dates.

How does an analyst think when communicating?

- Is the information confirmed, suspected, or unknown?
- Who needs it, for what purpose, and by what deadline?
- What classification, TLP, or contractual restriction applies?
- Is the channel secure and still trustworthy?
- Am I authorized to share it?
- What action or decision must the recipient take?
- Is legal, privacy, or management approval required?
- Was the message, recipient, response, and time documented?

Common mistakes

- Searching for a point of contact during the incident.
- Using compromised email or identity infrastructure for coordination.
- Sharing raw logs, personal data, or security architecture without need.
- Sending the same message to technical and executive audiences.
- Having no backup contacts or tested alternate channels.
- Contacting media, law enforcement, or regulators without authority.
- Failing to distinguish confirmed facts from hypotheses.
- Ignoring the system owner, data owner, and business impact.
- Applying another country's legal examples without local review.

Chapter summary

A SOC is a coordination capability as much as an analytical one. Relationships with management, IT, identity, legal, privacy, HR, GRC, business continuity, system and data owners, providers, regulators, and other external parties must be defined and tested in advance. A communication plan, RACI, contacts, TLP, need-to-know, templates, and alternate channels transform communication from improvisation into an incident response control that protects operations, evidence, privacy, and trust.

Chapter review questions

1. Who is a stakeholder in incident response?
2. Who normally communicates with the media?
3. What belongs in an incident communication plan?
4. What is the purpose and limitation of TLP?
5. Ransomware affects a payroll database. Which internal parties are required?
6. What is the difference between a CSIRT and a PSIRT?
7. Why is an out-of-band channel necessary?

8. What can an ISP or cloud provider contribute?
9. What should appear in the first management update?
10. Why does transparency not mean publishing every detail?

Practical exercise

Create a communication matrix for a critical incident. For each stakeholder, define primary and backup contacts, trigger, secure channel, allowed information, approval requirement, update frequency, and expected action.

Understanding SOC Metrics

Use measurement to improve the system, not to punish individuals.

Learning outcomes

- Define TTD, MTTD, MTTA, containment, eradication, recovery, and closure time.
- Separate tool delay from human and approval delay.
- Interpret mean, median, percentiles, and outliers.
- Measure true and false positives and false negatives.
- Build balanced operational and executive metrics.
- Govern metrics and connect them to business decisions.

Why Metrics Are Necessary

A SOC cannot be managed through impressions. Statements such as “we respond quickly” or “alert volume is high” do not reveal detection quality, delay, coverage, or business effect. Metrics turn performance into an auditable picture that supports decisions and improvement.

A good metric answers a question: Where is time being lost? Are high-severity alerts reliable? Are crown-jewel assets covered? Do playbooks work? Did an investment reduce downtime or exposure? Metrics should not push analysts to close tickets quickly at the expense of evidence or quality. That creates gaming and hides risk.

SIEM and security-data aggregation

SIEM often provides the broad data layer for SOC metrics because it collects, parses, normalizes, correlates, stores, alerts, and reports across sources. It is not plug-and-play. Scope, data model, parsing, retention, access, platform ownership, high availability, use cases, and lifecycle management all affect the reliability of the metrics.

From telemetry to coordinated response



No platform replaces business context, human judgment, or a defined authority model.

Figure 7-1. From telemetry to coordinated response. SIEM, case workflow, and response controls each have distinct roles; no platform replaces context, authority, or judgment.

Real-time or near-real-time data supports detection and response. Historical data supports baselines, trends, dwell-time analysis, hunting, audit, staffing, and post-incident review. Platform capacity also matters: delayed ingestion or slow searches can make a metric appear to show analyst failure when the root cause is sizing or engineering.

Single pane of glass: value and limitation

A dashboard can present notable events, queue state, coverage, severity, trends, and service status. It is a navigation and communication layer, not the only source of truth. Raw logs, original endpoint telemetry, packet data, evidence records, and business context remain necessary.

Time Definitions and Detection Outcomes

The starting and ending point of every time metric must be documented in a metric dictionary. Acronyms differ among organizations, especially MTTR. The same label can mean respond, remediate, resolve, restore, or recover.

Separate the time points in the incident lifecycle

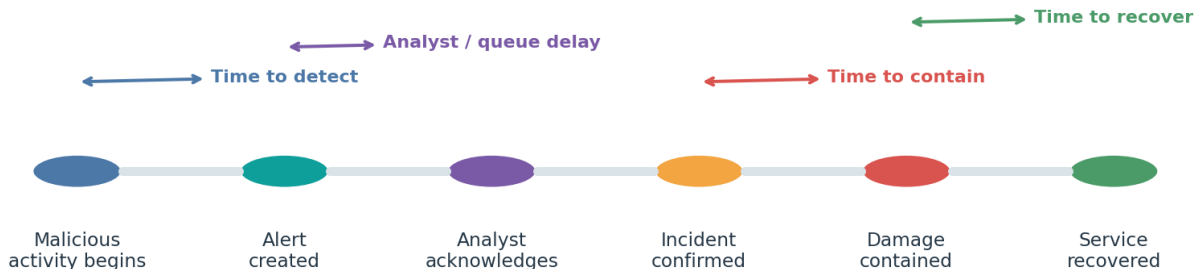


Figure 7-2. Separate the time points in the incident lifecycle. Tool, queue, confirmation, containment, and recovery time should not be collapsed into one number.

- **Time to Detect (TTD):** detection time for one incident, from the defined start of malicious activity or another agreed start point to detection.
- **Mean Time to Detect (MTTD):** the arithmetic mean of TTD values across a defined, comparable set of incidents. If median is reported, call it *median detection time*.
- **Mean Time to Acknowledge (MTTA):** average time from alert creation to analyst acknowledgment or queue acceptance.
- **Time to Confirm or Qualify:** time until the alert is classified as a real incident, a case requiring response, or another documented disposition.
- **Time to Report or Escalate:** time until the required case, level, or party is notified.
- **Time to Contain:** time until continuing damage or spread is stopped to the agreed containment condition.
- **Time to Eradicate or Remediate:** time until malicious presence and cause are removed or an approved fix or workaround is applied.
- **Time to Recover:** time until service returns safely to the agreed business state.
- **Time to Close:** may include final reporting, lessons learned, and administrative actions; it is not identical to recovery time.

Dwell time

Dwell time usually means the period from initial compromise until detection, but publications and organizations may use different boundaries. Document whether it ends at first detection, confirmation, or containment. Historical figures of 100 to 200 days provide context, not a target. M-Trends 2026 reported a global median dwell time of 14 days for investigated cases.^[13]

Lower MTTD does not prove maturity if case types, severity, detection sources, sample size, or the start definition changed. Segment the trend and interpret it with coverage and data health.

Separating tool time from human time

01:00 Malicious execution begins
01:04 EDR alert created
01:17 Tier 1 acknowledges
01:25 Tier 2 confirms incident
01:31 Endpoint effectively isolated

- Tool detection delay: 4 minutes.
- Queue and analyst acknowledgment delay: 13 minutes.
- Time to confirmation: 25 minutes from malicious execution.
- Time to containment: 31 minutes.

One aggregate number cannot show whether the problem lies in telemetry, rule logic, queue routing, staffing, analysis, integration, approval, or response execution.

Mean, median, percentiles, and outliers

The mean is the sum divided by the count and can be dominated by extreme cases. The median is the middle value and often represents typical performance better. Percentiles such as P90 and P95 reveal the tail that a median hides. Report count, mean, median, percentiles, maximum, severity, case type, and outlier review.

Containment times: 5, 7, 8, 10, 300 minutes
Mean: 66 minutes
Median: 8 minutes

The mean reveals the effect of the dangerous outlier; the median shows that most cases were faster. Both are needed.

Detection-control outcomes

		Detection outcome matrix	
		Alert	No alert
Malicious activity		TRUE POSITIVE	FALSE NEGATIVE
Benign activity		FALSE POSITIVE	TRUE NEGATIVE

Figure 7-3. Detection outcome matrix. False negatives are especially dangerous because malicious activity passes without an alert.

Table 7-1. Detection-control outcomes

Actual activity	Tool decision	Classification	Meaning
Malicious	Alert	True positive	Correct detection, still requiring assessment of timing and context
Benign	No alert	True negative	Correct non-alert for normal activity
Benign	Alert	False positive	Noise or an overly broad rule requiring tuning or context
Malicious	No alert	False negative	Malicious activity was missed; often discovered through hunting, external reporting, testing, or post-incident review

Too many false positives produce fatigue. Making detections too narrow in pursuit of a perfect false-positive rate can increase false negatives.

Precision and recall

- **Precision:** of the alerts produced, how many were true positives? Formula: $TP / (TP + FP)$.

- **Recall or sensitivity:** of the malicious activities in the evaluated set, how many were detected?
Formula: $TP / (TP + FN)$.

Precision cannot be interpreted reliably without a way to discover missed activity. Purple-team exercises, threat hunts, externally detected incidents, detection tests, and post-incident gap analysis help estimate false negatives.

A Balanced Metric Family

Speed

- TTD and median detection time.
- MTTA and queue age.
- Time to confirm, escalate, contain, eradicate, recover, and close.
- Approval, integration, and vendor delay.

Accuracy and quality

- True-positive, false-positive, benign-positive, and missed-detection review.
- Evidence completeness, correct scope, correct severity, reopens, and false actions.
- Precision, tested recall, and quality of enrichment.

Coverage and health

- Endpoint, identity, cloud, network, email, application, and database coverage.
- Critical-asset monitoring coverage.
- Log-source health, parsing success, latency, retention, and time synchronization.
- Detection-use-case and ATT&CK coverage with validation.

Process quality

- Playbook coverage, use, test date, success, exception rate, and steps skipped.
- Root-cause completion and corrective-action closure.
- Shift-handover quality and stakeholder update timeliness.
- Cases with a complete timeline, decision record, and closure criteria.

Automation

- Success and failure rate, partial failures, time saved, manual override, approval delay, false action, rollback, and idempotency errors.

People and sustainability

Use people metrics carefully and at an appropriate aggregation level. Useful indicators include training and skill coverage, on-call load, overtime, vacancy, turnover, repeated after-hours activation, and signs of workload imbalance. Measurement must not become intrusive surveillance.

Business value

- Downtime avoided or reduced.

- Critical services and records protected.
- Scope of loss, fraud, or disclosure reduced.
- Regulatory or contractual timeframes met.
- Cost per service or incident and investment directed to high-risk gaps.

SMART metrics

A useful metric target is Specific, Measurable, Attainable, Relevant, and Time-bound.

Poor: “Improve response.”

Better: “Increase the percentage of critical alerts acknowledged within five minutes from 68% to 90% by quarter end, while maintaining tested detection recall and without increasing false containment actions.”

Executive KPI examples

Table 7-2. Balanced executive SOC dashboard

KPI	Definition	Illustrative target	Decision supported
Critical MTTA	Critical alert creation to analyst acknowledgment	<= 5 minutes	Staffing, routing, paging, and coverage
Median time to contain	Confirmed critical incident to effective containment	<= 30 minutes	Authority, integration, and playbook design
Critical SLA compliance	Percentage of critical cases handled within agreed targets	>= 90%	Capacity and governance
EDR coverage	Active protected endpoints divided by in-scope inventory	>= 98%	Deployment and asset ownership
Critical log health	Critical sources current, parsed, and within latency threshold	>= 99%	Platform and data-owner action
False-positive rate	False positives divided by reviewed alerts	Downward trend with recall checks	Tuning and use-case redesign
Playbook coverage	Material incident types with approved and tested playbooks	>= 90%	Process maturity and exercise priorities
Corrective-action closure	Actions completed on time	>= 85%	Accountability and risk reduction

Targets are examples, not universal numbers. Each organization defines them according to risk, service commitments, resources, and the consequences of error.

Dashboards, Business Value, and Metric Governance

Event volume is a misleading metric

Alert or incident count can decrease because controls improved, a sensor failed, a rule was disabled, or the attack surface changed. It can increase because new sources were onboarded, coverage improved, a threat campaign began, or a rule became noisy. Interpret volume with coverage, health, case type, severity, and TP/FP data.

Historical reports and baselines

Historical data reveals peak hours, long-term changes, seasonality, staffing demand, tuning effects, and comparable incidents. A baseline does not prove that historical behavior was benign; a long-standing compromise can become part of the observed baseline. Combine it with hunting, intelligence, and business review.

Incident timeline and business impact

Time can be separated into dwell or detection, queue and reporting, containment, eradication, recovery, and business-impact duration. Improving one value at the expense of safety is not success. Immediate isolation may look excellent in a dashboard but be harmful if it stops a critical service unnecessarily. Speed must be paired with accuracy, authority, reversibility, and impact.

Measuring playbooks

Count alone is weak. Measure the percentage of material incident types covered; approval and review status; last exercise; use rate; exception and failure rate; skipped steps; automation success; time reduction; evidence completeness; and corrective actions. A playbook that is never tested or repeatedly fails can become a liability.

Zero-day detection metric

A “zero-day detections” metric can demonstrate behavior-based detection and hunting, but it is easily inflated. Define whether the event involved a previously unknown vulnerability, an exploit before an effective fix, a new malware variant, or simply a signature gap; identify who confirmed it and what evidence supports the claim. Do not use it as an unverified marketing number.

Operational cost and total cost of ownership

Include staff and on-call, SIEM/EDR/SOAR licensing, storage, compute, network, threat intelligence, providers, training, forensic retainers, integration, maintenance, availability, testing, and recovery. Value is not only cost reduction; it is the ability to direct investment toward the most dangerous gaps.

Monthly dashboard example

Total alerts: 20,000
Confirmed incidents: 600
Critical incidents: 25
MTTA: 18 minutes
Median detection time: 22 minutes
Median containment time: 45 minutes
Mean containment time: 3 hours
False-positive rate: 82%
EDR coverage: 88%
Critical log health: 93%
Critical SLA compliance: 68%
Playbook coverage: 54%

Interpretation

- 82% false positives: detection quality and context require tuning.
- MTTA of 18 minutes: queue routing, staffing, or paging is weak.
- Mean containment of three hours versus median 45 minutes: dangerous outliers require review.
- EDR coverage of 88%: a 12% endpoint blind spot.
- Log health of 93%: some metrics may be incomplete or biased.
- Critical SLA compliance of 68%: urgent cases are delayed.
- Playbook coverage of 54%: process readiness is incomplete.

Improvement sequence

1. Repair critical sensor and endpoint coverage.
2. Analyze the highest-volume and highest-cost false-positive rules.
3. Separate critical routing and on-call workflow from routine queue handling.
4. Review containment approval and integration delay.
5. Develop and exercise playbooks for recurring material incidents.
6. Measure the effect in the next reporting period.

Detection source: internal or external

Track whether incidents are detected internally, reported by a user, discovered by a hunt, reported by a partner or researcher, notified by a regulator or law-enforcement body, or announced by the adversary. External discovery may expose blind spots or long dwell time and should drive improvement rather than be hidden.

Context from the 2026 DBIR

The 2026 DBIR reported that vulnerability exploitation accounted for 31% of initial access, credential abuse 13%, the human element appeared in 62% of breaches, third-party involvement reached 48%, and ransomware appeared in 48% of breaches.^[14] These findings support metrics that extend beyond traditional network alerts to identity, patch and exposure, supplier, endpoint, awareness, and recovery coverage.

Metric governance

Every metric needs an owner, definition, data source, calculation, population, exclusions, frequency, segmentation, limitations, target, review date, and the decision it supports. When a rule, data source, platform, severity model, or definition changes, annotate the trend so unlike periods are not compared as if they were identical.

How does a SOC manager think?

- What story does the metric tell, and is the data complete?
- What is the root cause of the trend?
- Did one number improve at the expense of another?
- What are the outliers, and are cases comparable?
- What action, owner, due date, and validation follow?
- Can management understand the metric and connect it to a risk or service decision?

Common mistakes

- Using alert count as a success KPI.
- Using mean without median, percentiles, or sample size.
- Using MTTR without defining its start and end.
- Combining incomparable case types and severities.
- Building metrics from unhealthy or incomplete data.
- Closing tickets quickly to improve numbers.
- Using metrics to punish individuals.
- Ignoring business impact, false actions, and detection coverage.
- Copying targets from another organization without adaptation.
- Reporting a metric that supports no decision or improvement.

Chapter summary

Effective SOC measurement balances speed, accuracy, coverage, process quality, sustainability, cost, and business impact. Time boundaries and data definitions must be explicit. MTTD is a mean; median detection time should be reported separately. SIEM supplies data, but governance and context make the measurement trustworthy. Metrics should identify gaps and guide improvement, not decorate a dashboard or pressure analysts into unsafe behavior.

Chapter review questions

1. What is the difference between TTD and MTTD?
2. Why should tool detection time be separated from analyst acknowledgment time?
3. What is the most dangerous detection outcome?
4. Why report both mean and median?
5. MTTD is low but time to contain is high. What may explain the gap?
6. List five useful executive SOC metrics.
7. Does a large number of alerts prove maturity?

8. What is playbook coverage?
9. EDR coverage is 82% and critical log health is 91%. What should be prioritized?
10. How do SOC metrics connect to business value?

Practical exercise

Design a monthly dashboard with eight metrics. For each metric, define the formula, population, source, target, limitation, owner, and the management decision it supports.

Workflow Management and Automation

Remove repetition without removing accountability or human judgment.

Learning outcomes

- Explain case management, WMS, SOAR, and workflow boundaries.
- Distinguish sequential, state-machine, and rules-driven workflows.
- Integrate systems through APIs, STIX, and TAXII.
- Distinguish automation from orchestration and playbooks from runbooks.
- Apply human-in-the-loop, least privilege, approvals, audit, and rollback.
- Measure automation quality and handle partial failure.

Why a SOC Needs Workflow Management

A SOC faces volume, velocity, and complexity at the same time. Millions of events and thousands of alerts arrive across tools; important decisions may be required within minutes; and cases involve multiple teams, authorities, data sources, and systems. If every analyst handles an incident differently, tasks are lost, evidence is inconsistent, approvals are delayed, and service levels and audit become difficult to measure.

Organizations therefore use case-management, workflow-management, SOAR, XDR, SIEM, and ITSM capabilities to standardize and track work and automate repeatable tasks. Product boundaries vary, so functions should be evaluated rather than marketing labels.

What SOAR means

- **Security orchestration:** coordinating tools, data, tasks, people, and decisions.
- **Automation:** executing repeatable tasks automatically.
- **Response:** supporting or executing incident response under defined authority.

From telemetry to workflow

Centralized logging solved part of the problem by making data searchable. SIEM added normalization, correlation, and alerts. After an alert, another set of questions begins: Who owns the case? What enrichment is required? When is escalation due? Who can approve isolation? How are tasks, evidence, and results recorded? Workflow and case management answer these questions.

WMS: a generic term in this book

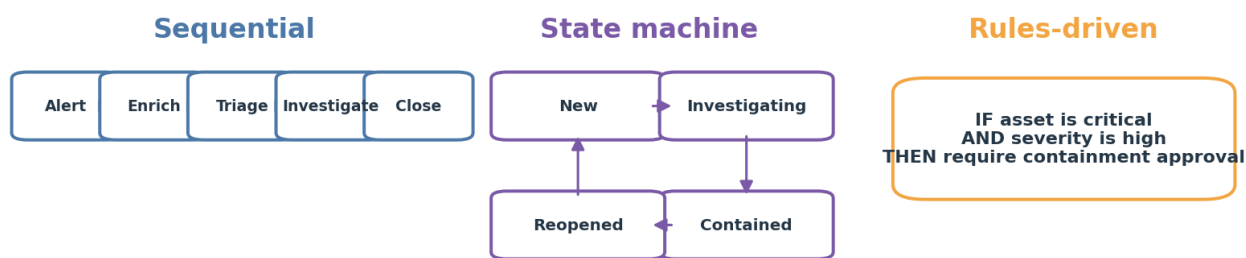
This book uses *workflow management system* as a generic description of a capability that creates or associates cases, assigns tasks, tracks state and SLA, gathers enrichment, manages approval gates, invokes integrations, records an audit trail, verifies closure criteria, and reports performance. It is not a claim that WMS is a universal SOC product category.

Functions may be distributed across SIEM, ITSM, SOAR, XDR, security case management, or a standalone workflow engine. SIEM/EDR/NDR are usually detection sources; ITSM and case platforms manage records and tasks; SOAR coordinates and executes; integrations allow the workflow to gather evidence, request approval, update a ticket, or perform a response action.

Workflow Management and Workflow Types

A workflow is the traceable execution of tasks and decisions under defined conditions and roles. Each step should specify trigger, input, responsible role, tool or integration, decision criteria, output, SLA, error handling, approval, verification, rollback, and audit fields.

Three workflow patterns



Mature incident workflows usually combine ordered steps, rules, parallel tasks, and reversible state changes.

Figure 8-1. Sequential, state-machine, and rules-driven workflow patterns. Mature incident workflows often combine ordered steps, rules, parallel work, and reversible state changes.

Sequential workflow

Moves forward through ordered steps such as Alert → Enrich → Triage → Investigate → Contain → Close. It is easy to train, audit, and automate and works well for stable procedures such as routine phishing triage. Its limitation is reduced flexibility when evidence changes or tasks must run in parallel.

State-machine workflow

Moves a case between states such as New, Investigating, Contained, Monitoring, Reopened, and Closed. It supports ransomware, data breach, and advanced incidents where evidence and severity change and a case may return to an earlier state. It requires governance to prevent uncontrolled loops or meaningless state changes.

Rules-driven workflow

Uses conditions to select a path, for example: if the asset is critical and confidence is high, notify the incident manager and require containment approval. Rules support classification, routing, escalation, and automation. Faulty rules can execute a harmful path at scale.

Table 8-1. Workflow types

Type	Movement	Suitable for	Primary risk
Sequential	Forward through ordered steps	Stable, routine, low-branching procedures	Difficulty returning or supporting complex parallel investigation
State machine	Between defined states, including return	Major incidents and changing evidence	Complexity, inconsistent state use, uncontrolled loops
Rules-driven	Path selected by conditions	Routing, escalation, enrichment, and automation	A faulty condition can misroute or execute a harmful action

Repeatable tasks suitable for automation

Log and alert enrichment

Run a time-bounded query, collect related alerts, add asset criticality, attach results, and record query time and source health.

User lookup

Retrieve department, manager, group membership, privilege, last logon, account state, and approved identity-risk context.

Device lookup

Retrieve IP, hostname, owner, location, operating system, business criticality, endpoint protection status, and known exposure.

Threat intelligence

Look up an IP, domain, URL, hash, or certificate; return source, confidence, first and last seen, related campaigns, and sharing label.

Case management

Create, assign, prioritize, start SLA timers, add tasks and evidence, update state, notify, and enforce closure criteria.

Callout and escalation

Page on-call staff, notify the incident manager, create a war room, or assign NOC and identity tasks based on severity and elapsed time.

External communication. Notification to regulators, law enforcement, customers, affected persons, or media should not be fully automated without legal, privacy, management, and policy approval.

Incident response workflow

Preparation

- Digitize policy, severity, SLA, playbooks, approval matrix, contacts, and closure criteria.
- Configure and secure integrations, credentials, logging, and non-production tests.

Detection and analysis

- Receive alert, create or associate case, enrich, triage, correlate, assign severity, and escalate.

Containment

- Propose action, request approval where required, execute through a control, verify the result, record evidence and time, and expose rollback.

Eradication and recovery

- Create tasks for patching, reimaging, credential rotation, restoration, validation, monitoring, and staged reconnection.

Post-incident

- Generate final report inputs, metrics, lessons learned, rule and playbook updates, and corrective-action tracking.

Severity changes and handover

A case may begin as medium, become critical when exfiltration or a crown-jewel asset is discovered, and move to monitoring after containment. The workflow should record who changed severity and why, recalculate targets, send new notifications, open tasks, and permit controlled reopening. Handover should expose current state, confirmed facts and hypotheses, pending tasks and approvals, evidence links, stakeholders, next update, and risks.

Roles within the workflow

- **Tier 1:** review alert and automated enrichment; validate severity and priority; close, escalate, or activate a defined path.
- **Tier 2:** investigate, determine scope, run endpoint/network/identity queries, and recommend containment.
- **Tier 3 and specialists:** perform advanced artifact, memory, PCAP, malware, and hunting analysis and produce new detection content.
- **Incident manager:** coordinate, track decisions and approvals, manage escalation, and enforce reporting cadence.
- **Management and owners:** review business impact and approve high-impact actions under policy.

Integration, APIs, STIX, and TAXII

Integration patterns

- **SIEM:** emits an alert or callout and receives case state or outcome.
- **ITSM or case management:** creates and updates cases, tasks, approvals, SLA, and evidence links.
- **Security controls:** EDR isolate or release; firewall block or unblock; identity restrict or revoke; email search and purge; sandbox submission; NDR query.
- **CMDB and asset inventory:** return owner, criticality, environment, dependencies, and service relationships.
- **Threat intelligence:** imports or exports context and indicators with confidence and sharing restrictions.

RESTful APIs

REST APIs commonly use HTTP methods such as GET, POST, PUT or PATCH, and DELETE. A defensive integration might retrieve asset details, create an incident, request endpoint isolation, or update a ticket.

```
GET /assets/{ip}
POST /incidents
POST /endpoints/{id}/isolate
PATCH /tickets/{id}
```

Integration controls

- TLS validation and approved network paths.
- Least-privilege tokens, RBAC, rotation, and secret storage in a vault.
- Input validation, output validation, rate limiting, timeout, and retry policy.
- Audit logs, correlation IDs, idempotency, and protection from duplicate execution.
- Versioning, change control, testing, and monitored failure.

Command-line integration

Legacy systems may require scripts or command-line tools. Risks include command injection, credentials in scripts, unstable output, weak error handling, difficult audit, and operating-system dependency. Isolate the integration service, validate and escape input, use limited accounts, parse output defensibly, and prefer documented APIs when available.

STIX and TAXII

STIX 2.1 is an OASIS language for representing cyber threat and observable information. TAXII 2.1 is an OASIS application-layer protocol for exchanging cyber threat intelligence over HTTPS APIs. TAXII can retrieve and share collections of STIX content; it is not a containment tool by itself.^{[9][10]}

Human-in-the-Loop and Automation Governance

Automation and orchestration

Automation executes a repeatable task, such as querying three reputation sources and adding the results to a case. **Orchestration** coordinates multiple tasks and tools: receive an alert, retrieve user and device context, create a case, request approval, isolate a device, verify the result, update the case, and notify stakeholders.

Playbook and runbook

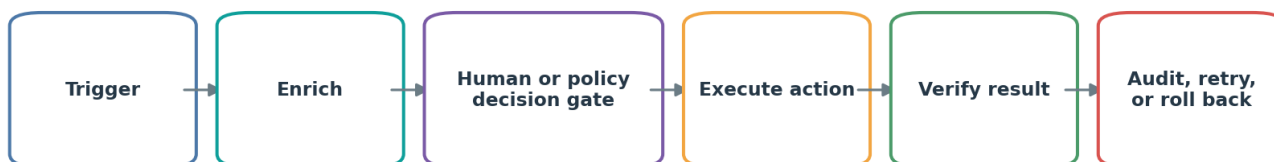
A playbook defines what to do, why, when, and who is responsible for an incident type. A runbook defines how to execute a specific step in a tool or environment, such as isolating an endpoint or revoking cloud sessions. One playbook may contain multiple runbooks.

Human-in-the-loop

Low-risk tasks such as enrichment, time-bounded queries, case creation, notification, and hash look-up are good candidates for automation. Human or policy approval is usually required for high-impact, irreversible, legally sensitive, or context-dependent actions such as isolating a critical server, disabling a domain administrator or service account, blocking a shared cloud service, removing messages from all mailboxes, stopping a production segment, or making an external disclosure.

The decision depends on confidence, asset criticality, reversibility, business context, time pressure, and the authorization matrix.

Governed automation workflow



Apply least privilege, secrets management, separation of duties, change control, and idempotency.

Figure 8-2. A governed automation workflow: trigger, enrichment, decision gate, execution, verification, and auditable failure handling or rollback.

Automation governance

- **Least privilege:** a query-only workflow does not need domain-administrator or endpoint-isolation rights.
- **Secrets management:** API keys, passwords, certificates, and tokens belong in a managed vault, not in workflow code.
- **Separation of duties:** the developer should not be the sole approver for production deployment.
- **Change management:** develop, test, peer review, approve, deploy gradually, monitor, and version.
- **Audit trail:** record trigger, inputs, rule decision, analyst or approver, action, result, time, error, retry, and rollback.
- **Verification:** confirm the real-world result rather than trusting a connector's success message.
- **Rollback:** define, authorize, and test reversal for each reversible action.

Failure handling and idempotency

If an IP block succeeds but the ticket update fails, the workflow must not report that the whole operation failed or repeat the block blindly. It should record partial success, preserve the response result, retry the safe step, stop dependent steps where necessary, alert an analyst, and use idempotency so a harmful action is not repeated.

Phishing automation example

Trigger: user report or email-security alert. **Automated steps:** extract headers, URLs, attachments, and message ID; calculate hashes; query approved intelligence; search mailboxes; retrieve click telemetry; create a case; attach evidence; suggest severity. **Human review:** decide whether the message is malicious, whether credentials were entered, whether an internal sender is compromised,

and whether broad search and purge is justified. **After approval:** purge messages, block confirmed indicators, revoke sessions or reset credentials, isolate an executed endpoint, and notify affected users.

Suspicious login and privilege escalation

VPN login from unusual network
MFA denied twice, then accepted
User added to privileged group
Access to customer database

Automated enrichment retrieves user, manager, department, VPN and MFA history, network context, group change, asset criticality, related alerts, and change records, then creates a critical case. Tier 1 validates enrichment and escalates. Tier 2 determines scope. An approval gate requests session revocation, account restriction, and rollback of unauthorized group membership.

Ransomware automation example

Trigger: mass file modification plus a suspicious process and C2. **Automation:** create a critical case, collect endpoint timeline, query the same behavior across endpoints, identify user and file shares, protect response credentials, and notify Tier 2, the incident manager, identity, and NOC. **Human-in-the-loop:** validate that activity is not a backup or deployment, review asset criticality and business impact, then approve host isolation and identity restriction. The workflow executes, verifies, records evidence, and exposes rollback.

Selecting a workflow or SOAR platform

- On-premises, cloud, tenancy, data residency, and provider access.
- Case management, state machine, parallel tasks, rules, and approval gates.
- Integrations, documented open APIs, extensibility, and exit capability.
- RBAC, secrets, audit, versioning, testing, HA/DR, and failure handling.
- Low-code usability versus code-based control and maintainability.
- Licensing, compute, storage, support, and total cost.

TheHive provides security case, task, and observable management and can integrate with analyzers and responders. Current documentation should be consulted because versions and capabilities evolve; as of 2026, TheHive 5 remains actively maintained.^[17]

Measuring automation success

- Time to enrich, acknowledge, escalate, and contain.
- Success, failure, and partial-failure rate.
- Manual override and approval delay.
- False action, outage, and rollback count.
- Hours saved and analyst effort redirected to higher-value work.
- Playbook coverage, use, test date, and cases with a complete audit trail.

The number of workflows is not a success metric. An unused workflow, one that fails silently, or one that creates outages has negative value.

How does the analyst think about a workflow?

- What triggered the workflow, and is the rule trustworthy?
- Is enrichment current, complete, and from healthy sources?
- What has been automated, and what requires human review?
- Is the asset critical and the action reversible?
- Did any connector or dependent step fail?
- Did the case record the decision, evidence, result, and approval?
- Is any task or rollback pending?
- Can the incident be closed safely, and what must be improved?

Common mistakes

- Automating an immature or contradictory process.
- Giving workflow accounts broad privileges.
- Having no approval, verification, rollback, or separation of duties.
- Relying on a single reputation result.
- Building large workflows that cannot be tested or understood.
- Failing to protect secrets or handle partial failure.
- Sending external notification automatically.
- Measuring playbook count rather than benefit and risk.
- Assuming automation replaces human judgment.

Chapter summary

Workflow and SOAR capabilities turn policies and playbooks into consistent, traceable, measurable digital operations. They integrate telemetry, case records, security controls, identity, asset context, and threat intelligence through APIs and standards such as STIX/TAXII. Good automation removes repetition while preserving human judgment for sensitive decisions and applying least privilege, secrets management, approval, audit, verification, idempotency, rollback, and failure handling. Success is the right action at the right time with controlled risk, not the largest number of automated actions.

Chapter review questions

1. What functions does workflow management provide inside a SOC?
2. How do sequential, state-machine, and rules-driven workflows differ?
3. What is the difference between automation and orchestration?
4. Which phishing tasks are good candidates for automation?
5. When should human-in-the-loop be used?
6. What are the roles of REST APIs, STIX, and TAXII?
7. Which controls are required for an automation account?
8. An IP block succeeds but the case update fails. What should the workflow do?
9. Which metrics are specific to automation?

10. Why does automation not replace a SOC analyst?

Practical exercise

Design an automated workflow for a suspicious login followed by privilege escalation. Mark automated enrichment, decision rules, human approval, response actions, verification, error handling, audit fields, and rollback.

Practical Appendices

Appendix A: Minimum Incident Record

Table A-1. Minimum incident record

Area	Required content
Identity and classification	Incident ID, title, severity, priority, status, detection source, owner, incident manager, timestamps
Scope	Users, identities, devices, applications, services, data, branches, cloud resources, and time period
Evidence	Alerts, original logs, queries, hashes, packet captures, screenshots, forensic images, artifact locations, source health, chain of custody
Analysis	Facts, hypotheses, confidence, timeline, initial access, root cause, affected assets and data, ATT&CK techniques where useful
Response	Actions proposed and executed, responsible party, approvals, verification, containment, eradication, recovery, and rollback
Communication	Stakeholders, messages, classification or TLP, contacts, decisions, regulatory and external notifications
Closure	Business impact, closure criteria, final disposition, lessons learned, corrective actions, owners, due dates, and validation

Appendix B: Professional Playbook Structure

1. **Purpose and scope:** incident type, in-scope assets, data, services, and exclusions.
2. **Triggers:** alerts, reports, intelligence, thresholds, and confidence.
3. **Severity and service targets:** classification criteria, acknowledgment, escalation, containment, and update times.
4. **Roles and RACI:** responsible, accountable, consulted, informed, and backups.
5. **Triage and evidence:** questions, data, minimum evidence, preservation, and source-health checks.
6. **Containment and approvals:** pre-authorized actions, human gates, verification, and rollback.
7. **Eradication and recovery:** remove cause, rebuild or patch, validate, restore, monitor, and reconnect.
8. **Communication:** audiences, templates, channels, classification, cadence, and external approval.
9. **Closure and improvement:** closure criteria, final report, lessons learned, corrective actions, detections, and metrics.

Appendix C: Executive Update Template

Incident / severity:

Current status: What has been confirmed so far?

Business impact: Which services, data, customers, or legal obligations may be affected?

Actions completed: Which containment or protective actions are verified?

Actions in progress: What investigation, eradication, recovery, and communication work continues?

Decision required: What decision is needed, from whom, and by what time?

Unknowns and risk: What remains unconfirmed or could change the response?

Next update: Exact time and responsible sender.

Appendix D: Defensive Ransomware Checklist

- Open a major incident and appoint an incident manager and technical lead.
- Preserve routine monitoring and sensor-health oversight.
- Isolate active sources and terminate malicious or high-risk SMB/RDP sessions under the playbook.
- Restrict compromised accounts, revoke tokens, and protect privileged and recovery identities.
- Protect backups, management planes, hypervisors, EDR, SIEM, and response credentials.
- Hunt for lateral movement, persistence, exfiltration, and additional encryption sources.
- Preserve required evidence before rebuilding or deleting artifacts.
- Remove malware, persistence, exploited weaknesses, and unauthorized access.
- Restore in phases from trusted copies with heightened monitoring and owner approval.
- Update indicators, detections, playbooks, risk, training, and corrective actions.

Appendix E: Shift Handover Template

Shift / time / analyst:

Open critical and high cases:

Confirmed facts:

Current hypotheses and confidence:

Actions completed and verified:

Pending tasks and owners:

Approvals or decisions pending:

Evidence and query locations:

Stakeholders and next update times:

Sensor, queue, and platform health:

Watch items for the next shift:

Appendix F: Metric Dictionary Template

Table A-2. Metric dictionary fields

Field	Description
Name and owner	Unique metric name and accountable owner
Purpose	Question or decision the metric supports
Definition	Exact numerator, denominator, start, end, inclusion, and exclusion
Source	System, table, field, query, and source-health dependency
Population and segmentation	Case types, severity, assets, regions, shifts, and time period
Frequency	Collection and review schedule
Target and threshold	Risk-based target, warning, and escalation point
Limitations	Bias, missing data, definition changes, and interpretation risks
Change log	Rule, platform, severity, population, and calculation changes
Action	Expected response, owner, due date, and validation when the threshold is missed

Model Answers and Exercises

The following answers are illustrative. Other formulations may be correct when they are supported by clear evidence, defined terminology, and organizational context.

Chapter 1 Answers: Introduction to the SOC

1. What is the SOC's core function?

To provide continuous security visibility, qualify and investigate suspicious activity, coordinate incident response, preserve an evidence-based record, and improve controls so threats cause less business harm.

2. Event, alert, and incident?

An event is an observable occurrence; an alert is a tool or rule judgment that activity warrants review; an incident is a security condition requiring coordinated management and response. Example: a failed login is an event, repeated failures followed by success from an unusual network may be an alert, and confirmed use of the account to access sensitive data is an incident.

3. What is dwell time and why does it matter?

It is the period from the defined initial compromise to detection. Longer dwell time gives an adversary more opportunity to explore, persist, steal data, disrupt services, and increase cost and reputational harm.

4. Who can be a threat actor?

Organized crime, state-affiliated groups, insiders, hacktivists, opportunistic attackers, compromised third parties, or any entity that conducts or supports harmful activity. Classification depends on motive, capability, access, resources, and evidence.

5. EDR sees 4,000 file changes in six minutes. First two decisions?

Determine whether damage is active and whether the fast-containment criteria are met; then isolate or stop the source from writing to the share and restrict the associated identity or sessions while opening a critical incident and investigating in parallel.

6. Why are backups alone insufficient?

Modern ransomware can steal data, destroy or encrypt backup infrastructure, compromise backup credentials, commit fraud, and extort through disclosure. Backups support recovery but do not provide detection, containment, identity protection, or breach prevention.

7. Why is unknown malware not automatically a zero-day?

Unknown malware may be a new variant, obfuscated file, or signature gap. A zero-day concerns a previously unknown or effectively unpatched vulnerability and, when relevant, an exploit that uses it.

8. Two people and two technology challenges?

People: burnout, skill shortage, retention, or knowledge concentration. Technology: missing telemetry, poor parsing, hybrid-environment blind spots, or tool integration and storage limits.

9. False positive resembling ransomware?

A legitimate backup, encryption, migration, synchronization, or software-deployment job that changes many files. Validate the process, owner, schedule, account, destination, and change record.

10. How does a SOC demonstrate business value?

By reducing downtime, loss, fraud, disclosure, and scope; accelerating reliable detection and containment; protecting critical services and trust; meeting obligations; and converting incidents into measurable control improvements.

Chapter 1 exercise guidance

Example timeline: initial access at 01:00; suspicious command execution at 01:12; credential use at 01:25; lateral movement at 01:40; mass SMB writes and alert at 02:00; containment at 02:06. Define dwell time from the assumed initial compromise. First containment may be endpoint isolation, SMB-session termination, and identity restriction under the playbook. Preserve endpoint, identity, file-server, network, and backup evidence and involve the file-service business owner.

Chapter 2 Answers: Processes and Services

1. Why continue routine monitoring during a major incident?

Other attacks may occur, the incident may be part of a wider intrusion, and losing visibility over the environment creates a new blind spot. A dedicated incident cell should not consume the entire monitoring capability.

2. Six operational phases?

Preparation; detection and analysis; containment; eradication; recovery; lessons learned. They are iterative rather than strictly linear.

3. Containment versus eradication?

Containment stops ongoing damage or spread. Eradication removes malicious presence, persistence, unauthorized access, and the exploited cause.

4. Who executes changes?

The team with operational authority - often NOC, IT, identity, endpoint, email, cloud, or application owners - executes the change. The SOC provides evidence and priority, the accountable role approves, and the result is verified and documented.

5. Phishing reached 80 users. What is required?

Message and header analysis, recipient and click search, credential and endpoint assessment, search and purge, indicator control, identity response, user communication, hunting, documentation, and lessons learned across SOC, email, identity, endpoint, HR, legal, and management as scope requires.

6. Why involve legal and privacy?

To assess monitoring authority, evidence, breach thresholds, notification and reporting obligations, contractual restrictions, privilege, and approved external communication.

7. What is qualification?

An evidence-based disposition that determines whether a case is a true positive, false positive, benign positive, policy violation, technical failure, or incident and identifies the required response.

8. What is the detection feedback loop?

The process of converting incident indicators, behaviors, root cause, and blind spots into improved rules, hunts, telemetry, controls, playbooks, and training.

9. Endpoint isolated but sessions not revoked. Risk?

The adversary may continue through existing tokens, another device, remote services, or the same credentials. Endpoint isolation alone may be partial containment.

10. Beginning service catalogue?

Monitoring and sensor health; alert triage; incident coordination; phishing and malware handling; identity and endpoint investigation; threat-intelligence enrichment; reporting; and lessons learned. Add hunting, forensics, and engineering as maturity grows.

Chapter 2 exercise guidance

The playbook should define intake, preservation of the original message, extraction and look-up, recipient and click search, credential and endpoint checks, decision criteria, search and purge, identity response, blocking, human approvals, user communication, case documentation, closure, detections, metrics, and rollback.

Chapter 3 Answers: Types and Deployment Models

1. Compare the three operational focuses.

Threat-centric emphasizes adversaries, hunting, modeling, and detections. Compliance-focused emphasizes evidence, controls, baselines, and reporting. Operational emphasizes monitoring, incident handling, containment, and recovery. Mature SOC combine them.

2. Highest data control?

An internal or dedicated SOC normally offers the highest direct control, with higher cost and a longer build time.

3. Why is virtual not synonymous with outsourced?

Virtual describes a geographically distributed or remote way of working. A virtual SOC may be fully internal, provider-operated, or hybrid; ownership and authority must be described separately.

4. Principal MSSP risks for a financial institution?

Data residency and privacy, provider access, limited internal context, escalation delay, dependency, inconsistent severity, constrained customization, evidence handling, and weak knowledge transfer.

5. Sensitive data, no SOC, medium budget: starting model?

A controlled hybrid/co-managed model: provider support for 24/7 monitoring and selected expertise, while incident ownership, high-impact decisions, sensitive data, evidence, and regulatory communication remain internal.

6. Why RACI, SLA, and common case management?

They prevent responsibility gaps, define time and quality expectations, establish one incident record, and make escalation, containment, reporting, and handover measurable.

7. When is compliance-focused capability insufficient?

When it proves that required controls exist on paper but lacks reliable detection, investigation, containment, recovery, and protection against threats outside the audit checklist.

8. Hybrid versus internal over three years?

Use hybrid to close urgent 24/7 and skill gaps; measure service quality and dependency; train internal staff; bring sensitive functions and use cases inside; consolidate tools and case management; then decide the target operating model based on risk, cost, and maturity.

9. TCO beyond licenses?

Staff, management, shifts, on-call, storage, compute, network, integrations, HA/DR, training, intelligence, forensics, testing, support, provider use, data transfer, migration, and exit.

10. Executive decision criteria?

Select the SOC model using business criticality, threat and risk, attack surface, data sensitivity and residency, regulation, operating hours, incident authority, current talent, startup time, total cost, provider access, resilience, knowledge transfer, and exit requirements.

Chapter 3 exercise guidance

A hybrid model is a defensible initial choice for the example. The internal team owns incidents, decisions, data, and business context; a provider supplies 24/7 Tier 1 and specialist support. Risks include external access, delay, and dependency. Controls include split architecture, least privilege, RACI/SLA, common case management, tested escalation, knowledge-transfer targets, audit rights, and an exit plan.

Chapter 4 Answers: Building an Effective Team

1. Who performs initial triage?

Tier 1 or the assigned monitoring and triage role, supported by automation and clear escalation criteria.

2. Tier 2 versus Tier 3?

Tier 2 performs deeper incident investigation, timeline, scope, and response coordination. Tier 3 handles advanced analysis, proactive hunting, complex response, forensics or malware expertise, and detection engineering.

3. SOC manager during a major incident?

Allocate people and shifts, preserve routine monitoring, appoint or support incident command, track severity and service targets, obtain decisions, coordinate stakeholders, review reports, and protect team sustainability.

4. Encoded scripting and external connection: enrichment?

User and asset context, process tree and command line, parent process, destination and DNS/TLS context, related alerts, network and identity activity, criticality, change records, endpoint health, and whether the activity continues.

5. IOA versus IOC?

An IOA is behavior or intent suggesting an attack; an IOC is an artifact associated with compromise. Behavior can remain useful after an address or hash changes.

6. What contributes to burnout?

Alert noise, shift disruption, understaffing, repetitive work, constant crises, limited authority, poor documentation, weak recognition, and insufficient development or rest.

7. Why structured overlap?

It improves knowledge transfer, flexibility, resilience, response speed, mentoring, and career progression while clear responsibility prevents chaos.

8. Who isolates a domain controller?

The accountable incident authority under the playbook, in consultation with identity, technical lead, system owner, and management. Tier 1 should not decide alone unless an extremely narrow pre-authorization explicitly covers the condition.

9. Typical tools by tier?

Tier 1: SIEM, case management, EDR, email, identity and asset lookup. Tier 2: advanced queries, endpoint, network, identity, sandbox, and vulnerability context. Tier 3: hunting, forensics, malware, packet, intelligence, and detection engineering. Management: queue, SLA, coverage, quality, workload, risk, and executive reporting.

10. Three burnout-reduction policies?

Tune and automate low-value noise; provide fair staffing, shift rotation, rest, and leave; and protect learning, mentoring, documentation, and rotation time. Measure team quality and system performance, not raw ticket closure.

Chapter 4 exercise guidance

Assign one accountable role per task. Tier 1 is responsible for triage; Tier 2 for investigation and scope; Tier 3 is responsible or consulted for advanced analysis; identity owns account actions; NOC owns network changes; the system owner owns service-impact input; legal is consulted for data and disclosure; the incident manager is accountable for coordination and approved response.

Chapter 5 Answers: Data and Tools

1. Five-tuple?

Protocol, source IP, source port, destination IP, and destination port.

2. Telephone-bill data?

Session or flow data. It shows communication relationships, timing, and volume but not necessarily content or user intent.

3. Session versus transaction?

Session summarizes a network communication; transaction records an operation within a protocol, service, application, database, identity system, or cloud API.

4. When use PCAP?

After narrowing the time and session, when packet or protocol detail, unencrypted content, artifact extraction, or forensic evidence is needed and privacy and retention allow it.

5. Periodic connection every 60 seconds?

Flow and statistical data show periodicity; DNS, proxy, firewall, TLS metadata, and PCAP add network context; EDR identifies the process; intelligence adds destination context.

6. Is alert data always most accurate?

No. It is a detector judgment that can omit context, be a false positive, or miss activity. Validate it against original and independent sources.

7. Conceptual role of Security Onion?

An integrated network security monitoring and log-analysis platform that helps analysts move from detections and metadata to packet, endpoint, search, and case evidence.

8. Vulnerability assessment versus penetration test?

Assessment identifies and prioritizes potential weaknesses. Penetration testing attempts to validate exploitability and impact under explicit authorization, scope, safety, and rules of engagement.

9. Sources for database exfiltration?

Database audit and application transactions, endpoint process telemetry, identity and service-account logs, firewall/proxy/flow, DNS, DLP, SIEM, job schedules, change records, system and data owners, and intelligence on the destination.

10. Why question before tool?

Because the hypothesis determines the evidence required. Selecting a familiar console first can bias the investigation and overlook the source that can actually prove or refute the question.

Chapter 5 exercise guidance

Test authorization through schedules and owners; determine data through database audit; identify the process and account through EDR and identity; measure destination and volume through network telemetry; assess context through intelligence; check continuity through flow and DLP; then perform proportionate, approved containment and preserve evidence.

Chapter 6 Answers: Stakeholders

1. Who is a stakeholder?

Any person, team, organization, or external party affected by the incident or holding information, authority, a service, a decision, or an obligation related to it.

2. Who communicates with media?

The approved public-affairs or communications spokesperson, coordinated with management and legal. Analysts provide facts through internal channels.

3. Communication-plan elements?

Purpose, scope, activation, audiences, roles, contacts and backups, classification, triggers, channels, templates, approvals, escalation, external and media communication, training, testing, maintenance, and lessons learned.

4. Purpose and limitation of TLP?

TLP defines permitted sharing of information. It does not replace classification, privacy law, contracts, need-to-know, or handling controls.

5. Payroll ransomware stakeholders?

SOC/CSIRT, incident manager, DBA and system owner, identity, NOC/IT, endpoint, backup, HR and data owner, legal/privacy/compliance, CISO, management, and business continuity; external parties as required.

6. CSIRT versus PSIRT?

A CSIRT responds to incidents affecting a constituency's systems and services. A PSIRT focuses on vulnerabilities and incidents involving a vendor's products.

7. Why out-of-band?

Primary email, identity, network, or collaboration systems may be compromised, unavailable, monitored by the adversary, or unsuitable for sensitive coordination.

8. ISP or cloud provider role?

DDoS mitigation, upstream blocking, evidence and log preservation, snapshot or object retention, key or resource suspension, workload isolation, and shared-responsibility recovery support.

9. First management update?

Confirmed facts, severity, current business and data impact, actions complete and in progress, decisions required, key unknowns and risks, confidence, and the next update time.

10. Why not publish every detail?

Honest communication still must protect personal data, evidence, legal privilege, investigation integrity, sensitive architecture, contracts, and information that could help the adversary.

Chapter 6 exercise guidance

The matrix should include CISO, management, NOC, identity, system and data owners, legal/privacy, HR, public affairs, provider, regulator, and law enforcement when relevant. Define trigger, content, TLP or classification, secure channel, primary and backup contact, approval, update frequency, and required action.

Chapter 7 Answers: Metrics

1. TTD versus MTTD?

TTD is detection time for one incident. MTTD is the arithmetic mean of TTD values across a defined comparable set. Median detection time is a separate statistic.

2. Why separate tool and analyst time?

To identify whether delay comes from telemetry and detection, ingestion and routing, queue and staffing, analysis, approval, integration, or execution. One combined value hides the cause.

3. Most dangerous outcome?

A false negative: malicious activity occurred and the control produced no alert.

4. Mean and median?

Mean shows the overall arithmetic effect and is sensitive to extreme delays. Median shows the typical middle case. Use both with percentiles, maximum, sample size, and outlier review.

5. Low MTTD, high containment time?

Detection may be strong while response is delayed by routing, staffing, investigation, asset ownership, approval, integrations, provider escalation, or unavailable runbooks.

6. Five executive metrics?

Examples: critical MTTA, median detection time, median containment time, critical SLA compliance, EDR or critical-log coverage, false-positive rate, playbook coverage, corrective-action closure, and business downtime.

7. Do many alerts prove maturity?

No. Volume may indicate attacks, improved coverage, poor tuning, duplicated data, or a broken rule. Interpret it with health, coverage, severity, and outcomes.

8. What is playbook coverage?

The percentage of material incident types or use cases with an approved, current, used or exercised, and measurable playbook.

9. EDR 82%, log health 91%: priority?

Close critical blind spots and restore source health before relying on metrics or optimizing detection content. Improvement decisions are weak when the evidence layer is incomplete.

10. Connect metrics to business value?

Translate technical performance into reduced downtime, fraud, data loss, disclosure, regulatory risk, incident scope, and safer investment decisions for critical services.

Chapter 7 exercise guidance

A balanced dashboard can include critical MTTA, median detection time, median containment, SLA compliance, false-positive rate with recall tests, EDR coverage, critical-log health, and playbook coverage. Each metric must define formula, source, population, target, limitation, owner, and decision.

Chapter 8 Answers: Workflow and Automation

1. Workflow-management function?

Organize cases, tasks, states, roles, deadlines, approvals, integrations, response actions, evidence, audit, handover, closure, and reporting.

2. Sequential, state-machine, and rules-driven?

Sequential follows ordered steps; state-machine allows controlled movement and return between states; rules-driven selects a path based on conditions. Mature workflows often combine all three with parallel tasks.

3. Automation versus orchestration?

Automation executes one repeatable task. Orchestration coordinates multiple tasks, tools, decisions, and people to complete a workflow.

4. Automatable phishing tasks?

Extract headers, URLs, and attachments; hash and approved lookup; search mailboxes; retrieve click data; enrich user and device; create and update the case; attach evidence; and send internal notifications. Impact decisions and external communication require human control.

5. When human-in-the-loop?

For high-impact, irreversible, legally sensitive, uncertain, or business-context-dependent actions such as isolating critical services, disabling privileged identities, broad email removal, or external disclosure.

6. REST, STIX, and TAXII?

REST APIs exchange system data and commands. STIX represents threat and observable information. TAXII transports threat-intelligence collections over standardized HTTPS APIs.

7. Automation-account controls?

Least privilege, RBAC, managed secrets, rotation, network restrictions, TLS, input validation, logging, rate limits, change control, separation of duties, monitoring, and tested rollback.

8. Block succeeded but ticket update failed?

Record partial success, preserve the block result, do not repeat the harmful action, retry or route the safe update, alert an analyst, stop dependent work if required, and roll back only under policy and evidence.

9. Automation metrics?

Success, failure, partial failure, false action, time saved, improvement in response time, approval delay, manual override, rollback, idempotency errors, workflow use, and complete audit trail.

10. Why automation does not replace analysts?

Intent, uncertainty, business impact, ethics, law, novel behavior, evidence quality, and high-impact decisions require human judgment. Automation removes repetition and accelerates approved work.

Chapter 8 exercise guidance

Trigger from identity or SIEM; enrich from VPN, MFA, directory, HR, CMDB, change, endpoint, and intelligence; route to Tier 1; escalate on privileged change and critical asset; require approval to restrict a privileged account; execute through limited APIs; verify outcome; record audit and partial failure; provide rollback after validation.

Concise Glossary

Alert

A notification generated by a tool, rule, signature, model, or analytic when activity warrants review; it is not a final judgment.

Artifact

A digital trace or object related to an incident, such as a file, log, memory image, certificate, or email header.

Asset criticality

The importance of an asset or service to the business and the impact of its outage or compromise.

Attack surface

The total set of exposed points, identities, dependencies, interfaces, and paths through which a system may be attacked.

Baseline

A model of expected behavior used for comparison; historical behavior is not automatically benign.

Beaconing

Periodic or patterned communication that may indicate command and control.

Benign positive

An alert that correctly identifies the behavior described by the rule, but the behavior is authorized or non-malicious in context.

Case management

The capability that organizes incident records, owners, tasks, evidence, decisions, communication, and closure.

Containment

Actions that stop or limit continuing damage and spread without necessarily removing root cause.

Correlation

Linking evidence from multiple sources by time, identity, asset, behavior, or context to form an incident story.

Dwell time

The period from the defined initial compromise until detection or another explicitly stated endpoint.

Enrichment

Adding user, asset, vulnerability, reputation, business, or threat context to an alert or case.

Eradication

Removal of malicious presence, persistence, unauthorized access, and the weakness or cause that enabled the incident.

Event

An observable occurrence in a system or network that may be normal, suspicious, or malicious.

False negative

Malicious activity that the evaluated control or detector failed to alert on.

False positive

An alert for activity later determined to be benign or not the security condition intended by the detector.

Human-in-the-loop

A design in which a person reviews or approves a decision before a sensitive action is executed.

Incident

A security condition, policy violation, or imminent threat requiring organized management and response.

Indicator of attack

Behavior, sequence, or intent that suggests an attack is occurring.

Indicator of compromise

An artifact or observable associated with compromise, such as a hash, domain, registry value, or certificate.

Lateral movement

Adversary movement between systems, services, identities, or trust zones inside an environment.

Least privilege

Granting only the access and action rights required for a defined task and duration.

Orchestration

Coordination of multiple tools, tasks, people, and decisions to complete a workflow.

Playbook

A structured response plan that defines what to do, when, why, and who is responsible for an incident type.

Runbook

Detailed execution instructions for a specific task, tool, or environment.

Scope

The identities, assets, services, data, locations, and time affected or potentially affected by an incident.

Telemetry

Operational and security data collected from systems, identities, networks, applications, cloud, and tools.

Threat hunting

Proactive, hypothesis-driven searching for malicious behavior that did not produce a clear alert.

Triage

Initial validation, prioritization, enrichment, disposition, and routing of an alert or report.

Zero trust

An architecture and operating approach that removes implicit trust and continuously verifies access to resources.^{ref(8)}

Zero-day vulnerability

A weakness for which defenders lack effective public knowledge or a suitable vendor fix at the relevant time; unknown malware alone is not a zero-day.

Subject Index

Page numbers are resolved from the section where each concept is introduced or discussed most directly.

Active Directory / identity [42](#)

Alert / event / incident [16](#)

Attack progression / ATT&CK [19](#)

Automation / orchestration / SOAR [85](#)

Backup and recovery [26](#)

Beaconing / C2 [51](#)

Business continuity [21](#)

Case management [54](#)

Containment / eradication / recovery [26](#)

Data exfiltration [56](#)

Detection engineering / threat hunting [34](#)

Dwell time / MTTD / MTTA [71](#)

EDR / XDR / NDR [54](#)

Evidence / forensics / chain of custody [54](#)

False positive / false negative [71](#)

Incident communication / stakeholders [61](#)

Incident response / CSIRT [26](#)

Internal / outsourced / hybrid SOC [36](#)

IOC / IOA / TTPs [42](#)

Metrics / SLA / dashboard [74](#)

NetFlow / IPFIX / PCAP / DNS [51](#)

Phishing / social engineering [18](#)

Playbook / runbook / SOP [85](#)

Qilin / ransomware [19](#)

RACI / TLP / need-to-know [64](#)

Security Onion / SIEM / TheHive [54](#)

SOC staffing / Tier 1 / Tier 2 / Tier 3 [42](#)

STIX / TAXII / threat intelligence [84](#)

Vulnerability assessment / penetration testing [54](#)

Workflow management [81](#)

Zero trust / least privilege / MFA [85](#)

References and Sources

The original instructional organization was retained and corrected using the following primary and official sources. Accessed or verified in July 2026 unless a publication year is shown.

1. National Institute of Standards and Technology. *NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. 2025. <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
2. National Institute of Standards and Technology. *The NIST Cybersecurity Framework (CSF) 2.0*. 2024. <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final>
3. FIRST. *CSIRT Services Framework, Version 2.1*. 2020. https://www.first.org/standards/frameworks/csirts/csirt_services_framework_v2-1
4. FIRST. *Traffic Light Protocol (TLP), Version 2.0*. 2022. <https://www.first.org/tlp/>
5. Carnegie Mellon University Software Engineering Institute / CERT. *A Guide to Effective Incident Management Communications*. 2020. https://resources.sei.cmu.edu/asset_files/Handbook/2021_002_001_651819.pdf
6. MITRE. *MITRE ATT&CK Enterprise Matrix*. <https://attack.mitre.org/matrices/enterprise/>
7. MITRE ATT&CK. *Qilin - Software S1242*. <https://attack.mitre.org/software/S1242/>
8. National Institute of Standards and Technology. *NIST SP 800-207: Zero Trust Architecture*. 2020. <https://csrc.nist.gov/pubs/sp/800/207/final>
9. OASIS Open. *TAXII Version 2.1*. 2021. <https://www.oasis-open.org/standard/taxii-version-2-1/>
10. OASIS Open. *STIX Version 2.1*. 2021. <https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html>
11. Center for Internet Security. *CIS Critical Security Controls Version 8.1*. <https://www.cisecurity.org/controls/v8-1>
12. Cybersecurity and Infrastructure Security Agency. *StopRansomware Guide*. Current online guidance accessed July 2026. <https://www.cisa.gov/stopransomware>
13. Google Cloud / Mandiant. *M-Trends 2026*. 2026.
14. Verizon. *2026 Data Breach Investigations Report*. 2026.
15. Security Onion Solutions. *Security Onion 2.4 Documentation*. <https://docs.securityonion.net/>
16. Splunk. *Splunk Product Documentation*. <https://docs.splunk.com/Documentation>
17. StrangeBee. *TheHive Documentation*. Current documentation accessed July 2026. <https://docs.strangebee.com/thehive/>
18. National Institute of Standards and Technology. *NIST SP 800-86: Guide to Integrating Forensic Techniques into Incident Response*. 2006. <https://csrc.nist.gov/pubs/sp/800/86/final>
19. National Institute of Standards and Technology. *NIST SP 800-184: Guide for Cybersecurity Event Recovery*. 2016. <https://csrc.nist.gov/pubs/sp/800/184/final>
20. ISC2. *CISSP Experience Requirements*. Current official requirements accessed July 2026. <https://www.isc2.org/certifications/cissp/cissp-experience-requirements>